

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain A - GRC

Table of Contents

Domain A - Governance, Risk, and Compliance (GRC) & Oversight.....	5
A1. Governance Policy Agent.....	5
Agent Blueprint [Informative].....	5
Technical Implementation Details (A1) [Informative]	16
MCP-Native Protocol Specification (A1) [Normative]	19
A2. Risk Analysis Agent.....	19
Agent Blueprint [Informative].....	19
Technical Implementation Details (A2) [Informative]	30
MCP-Native Protocol Specification (A2) [Normative]	32
A3. Compliance Auditor Agent	33
Agent Blueprint [Informative].....	33
Technical Implementation Details (A3) [Informative]	46
MCP-Native Protocol Specification (A3) [Normative]	48
A4. Policy Authoring Agent	49
Agent Blueprint [Informative].....	49
Technical Implementation Details (A4) [Informative]	61
MCP-Native Protocol Specification (A4) [Normative]	63
A5. Evidence Collector Agent	64
Agent Blueprint [Informative].....	64
Technical Implementation Details (A5) [Informative]	77
MCP-Native Protocol Specification (A5) [Normative]	79
A6. Control Monitor Agent.....	80
Agent Blueprint [Informative].....	80
Technical Implementation Details (A6) [Informative]	92
MCP-Native Protocol Specification (A6) [Normative]	94
A7. Metrics Aggregator Agent.....	94
Agent Blueprint [Informative].....	94
Technical Implementation Details (A7) [Informative]	105
MCP-Native Protocol Specification (A7) [Normative]	106

A8. Supplier Risk Agent.....	107
Agent Blueprint [Informative].....	107
Technical Implementation Details (A8) [Informative]	118
MCP-Native Protocol Specification (A8) [Normative]	119

Domain A - Governance, Risk, and Compliance (GRC) & Oversight

A1. Governance Policy Agent

Agent Blueprint [Informative]

Purpose: Author, version, and publish enterprise security policies/standards; co-sign sensitive actions.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Draft policies/standards as PRs** (GitHub/GitLab webhooks + REST): titles, diffs, file paths, approvers, CI checks.
- **Control evidence and mappings** (GRC REST/GraphQL): evidence records, control IDs (e.g., AU-12), coverage metrics, attachments.

Model training / knowledge (what the LLM relies on):

- Style and rubric fine-tuning or prompt pack (NIST 800-53, CIS, ISO/IEC 27002 mapping norms).
- RAG sources (policy repo history, control catalog, evidence index; do not train on regulated evidence; use evidence_refs).
- Guardrails (allowlist of repo paths; deny writes outside policy registries; constrained Git/GRC scopes).

Decisions it makes (deterministic + model-assisted):

- Policy acceptance vs. revision based on rubric + evidence linkage; emits line-level comments and fixes.
- Bundle build and publish (compile OPA bundle, verify checksums, sign, push).
- Co-sign gate: determine if a downstream ContainmentCommand needs policy_cosign (e.g., isolate_host or disable_account on CrownJewels); issue or deny co-sign with rationale.
- Classification choice for policy artifacts (promote C1 → C2 when topology/vendor detail is present).

Routing / where outputs go:

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- Policy bundles → Git (main) or OCI policy registry (tag, update policy index, write evidence_ref entries).
- Co-signatures → SOAR/orchestrators as gRPC metadata bound to the action message (plus journal append).
- Remediation/tickets → open/link issues when rubric violations or publish/co-sign checks fail.

Automation scope vs. manual/HITL:

- Fully automated: PR linting, control cross-references, bundle build, signature, publish to staging, evidence indexing.
- **HITL required:** co-signs for isolate_host or disable_account on CrownJewels; merges that weaken privileged policies (blast radius high or change_risk >= 0.7).
- Manual outside agent: new framework adoption (e.g., add ISO 27017); dispute resolution when evidence contradicts rubric and requires management arbitration.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **GitHub/GitLab Webhooks & REST** — draft policies/standards as PRs (Markdown/YAML)
2. **GRC Platform REST/GraphQL** — control evidence and mappings (e.g., Archer, ServiceNow GRC, OneTrust)

Example: Consumed Protocol — GitHub/GitLab Webhooks & REST [Informative]

Native payload

```
{
  "action": "opened",
  "repository": "sec/policies",
  "pull_request": {
    "number": 173,
    "title": "Std: Endpoint Logging AU-12 v1.3",
    "head": {"sha": "9f2a1cd"},

```

```

"base": {"ref": "main"},
"user": {"login": "policies-bot"},
"files_changed": [
  "standards/AU-12-endpoint-logging.md",
  "baselines/linux/auditd.yml"
]
}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a1-git-1111-2222-3333-4444",
    "thread_id": "uuid-pr-173",
    "task_id": "uuid-a1-task-0001",
    "role": "GovernancePolicyAgent",
    "intent": "govern",
    "policy_refs": ["AU-12", "CM-6"],
    "constraints": ["policy_cosign"],
    "decision_basis": {
      "evidence_refs": ["uri://github/sec/policies/pulls/173/files"],
      "confidence": 0.92,
      "explanation_ref": "uri://kb/policy/au12-logging-rationale-v1.3"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/governance-policy-agent",

```

```

    "signing_kid": "kid-gh-a1-01",
    "attestation_ref": "uri://slsa/attestations/governance-policy@sha256:gh01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — GRC Platform REST/GraphQL [Informative]
Native payload

```

{
  "evidence_id": "EV-CTRL-AU12-2025-0815-07",
  "control_id": "AU-12",
  "type": "log_sampling_report",
  "period_start": "2025-07-15T00:00:00Z",
  "period_end": "2025-08-15T00:00:00Z",
  "coverage_percent": 98.9,
  "attachments": [
    "s3://grc-evidence/au12/reports/2025-08/report.pdf",
    "s3://grc-evidence/au12/export/otlp-sample.csv"
  ],
  "owner": "sec.logging"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",

```

```

"mission_id": "uuid-a1-grc-5555-6666-7777-8888",
"thread_id": "uuid-evidence-EV-CTRL-AU12-2025-0815-07",
"task_id": "uuid-a1-task-0002",
"role": "GovernancePolicyAgent",
"intent": "govern",
"policy_refs": ["AU-12"],
"constraints": ["policy_cosign"],
"decision_basis": {
  "evidence_refs": [
    "uri://grc/evidence/EV-CTRL-AU12-2025-0815-07",
    "s3://grc-evidence/au12/reports/2025-08/report.pdf"
  ],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/policy/evidence-linkage#au12"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/governance-policy-agent",
  "signing_kid": "kid-grc-a1-02",
  "attestation_ref": "uri://slsa/attestations/governance-policy@sha256:grc02"
},
"classification": "C3",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- Policy bundles to Git or policy registry (OPA bundle → OCI).
- Co-signatures to SOAR/orchestrators via gRPC metadata (gate on protected actions).

MCP context (required) [Informative]

mission_id; role="GovernancePolicyAgent"; intent="govern"; policy_refs=[...]; constraints=["policy_cosign"]; provenance.attestation (SLSA/SPIFFE + KID)

MCP context (optional) [Informative]

classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

Containment gateways (SOAR/EDR) must verify this agent's co-signature before honoring a ContainmentCommand on protected assets.

NIST SP 800-160v2 linkage [Informative]

Develop/Implement/Maintain — encode and assure security requirements as policy with authoritative provenance.

Automation feasibility [Informative]

High (draft/merge automation + cryptographic co-sign; HITL for sensitive deltas).

Output Contracts (merged) [Informative]

OC-1: PolicyBundlePublish (Git or Policy Registry) [Informative]

- **Producer(s):** A1
- **Topic/Path:** repo=sec/policies (branch=main), or oci://policy-registry/<org>/<bundle>:<version>
- **Schema/Format:** OPA bundle manifest + data/; commit or image digest recorded as evidence_ref
- **Classification:** C1 default; C2 if policy reveals sensitive topology/vendor detail
- **Delivery:** at-least-once
- **Ordering:** per-policy-id
- **Idempotency-Key:** sha256(policy_id, version)

- **Ack/Nack:** Git commit or OCI 201 Created is ACK; NACK is HTTP 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on failure open ticket and halt downstream publish
- **Side-Effects:** tag release; update policy index; link digest in evidence store
- **HITL Token:** required for changes impacting CrownJewels or break-glass actions
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PolicyBundle@1.1 | json_schema_uri=uri://schema/policybundle-1.1.json | sha256= | producers=A1 | consumers=Registry-01, PolicyRepo-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PolicyCoSign (gRPC metadata for protected actions) [Informative]

- **Producer(s):** A1
- **Attachment:** metadata on the action (e.g., ContainmentCommand RPC or envelope)
- **Metadata keys:** x-govpolicy-sig (JWS), x-govpolicy-kid, x-govpolicy-valid-until, x-govpolicy-policy-refs
- **Classification:** C2+
- **Delivery:** exactly-once per action_id (consumer enforces idempotency)
- **Ordering:** per-action_id
- **Idempotency-Key:** sha256(action_id, target_id, valid_until_floor_60s)
- **Ack/Nack:** orchestrator ACK<=30s; retry exp-backoff<=5x; escalate to HITL on repeated NACK/timeout
- **Side-Effects:** append immutable co-sign record to audit journal; link to case ticket

- **HITL Token:** required for isolate_host or disable_account on CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.confidence, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When protected actions target CrownJewels assets OR requires_cosign=true in action metadata

schema_id=PolicyCoSign@1.0 | json_schema_uri=uri://schema/policy-cosign-1.0.json | sha256= | producers=A1 | consumers=SOAR-01, EDR-PEP-01 | accepts=1.0–1.1

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** A1, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-policy-id
- **Idempotency-Key:** sha256(policy_id, dispute_id)
- **Ack/Nack:** case_id assigned in <= 30 s else retry/backoff
- **Side-Effects:** open legal/compliance workflow; freeze related publishes if severity high
- **HITL Token:** required when dispute severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled for this deployment

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json | producers=A1, Legal-Portal-01 | consumers=Legal-01, Compliance-01 | accepts=1.0–

1.x

Conformance: Normative if implemented or claimed.

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** A1
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, policy_id)
- **Ack/Nack:** SIEM/CaseID assigned in <= 30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach bundle diffs and evidence_refs
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** per IR policy (>= 1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: ChangeImpactReport (Policy Drift and Change Management) [Informative, optional]

- **Producer(s):** A1 (pre-merge)
- **Topic/Path:** sec.policy.change_impact
- **Schema/Format:** ChangeImpactReport@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-pr-id

- **Idempotency-Key:** sha256(pr_id, commit_sha)
- **Ack/Nack:** PR comment/reference created; retry/backoff
- **Side-Effects:** gate to staging/production per thresholds
- **Observability:** trace_id, mission_id, policy_refs, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; A1 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, artifact_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to learning queue (governance-reviewed)
- **Observability:** trace_id, mission_id, artifact_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year (or per HR/Legal)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, reviewing_pr, generating_bundle, publishing, cosigning, contestation_workflow, failed, closed }
transition(idle -> reviewing_pr) when PR opened or evidence update received
transition(reviewing_pr -> generating_bundle) when CI passes and approvals met
transition(generating_bundle -> publishing) when checksums match and tests pass
transition(publishing -> cosigning) when downstream action requires policy_cosign
transition(reviewing_pr -> contestation_workflow) when PolicyDispute opens or stakeholder_disagreement_score >= 0.5
transition(* -> failed) on timeout or validation error
timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff
idempotency_key = sha256(policy_id, version) for publish; sha256(action_id, target_id, valid_until_floor_60s) for cosign

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PolicyBundlePublish	Required	Always	Core policy distribution
OC-2 PolicyCoSign	Conditionally Required	Protected actions on CrownJewels OR requires_cosign=true	Security control enforcement
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Change impact scoring enabled	Risk management
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- `policy_refs`: AC-2, CM-6, AU-12 (+ internal standards)
- **HITL required:** co-signs on CrownJewels actions; merges that weaken privileged policies
- **Automatic HITL escalation triggers:** `model_confidence < theta_low`; `model_drift_detected = true`; `stakeholder_disagreement_score >= 0.5`
- **Manual outside agent:** new framework adoption; managerial arbitration on conflicting evidence

SLOs and KPIs [Informative]

- `PolicyPublishAck_p95` $\leq$ 60 s
- `CosignAck_p95` $\leq$ 30 s
- `FalseCosignRate_7d` $\leq$ 1 percent
- `PolicyRollbackRate_30d` $\leq$ 2 percent
- `ModelValidation_SLA`: `eval_pass_rate_7d` $\geq$ 99.5 percent
- `DriftDetect_MTTD` $\leq$ 24 h
- `AppealResolution_p95` $\leq$ 5 business days

Outputs index [Informative]

[OC-1 PolicyBundlePublish], [OC-2 PolicyCoSign], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (A1) [Informative]

Model and training profile [Informative]

model_id=governance-text-model; temperature=0.1; max_tokens_out=800
prompt_pack_id=gov-policy-v1 (system prompt, rubric, few-shots)
RAG: sources={policy repo, control catalog, evidence index}; max_docs=8;
min_similarity=0.78; citations required
fine_tuning/adapters: none initially; if added, exclude regulated evidence; eval gates on
rubric compliance and hallucination bounds
guardrails: path allowlist; deny non-policy registries; scoped Git/GRC tokens

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (PRs, approvals, evidence_refs), ttl=365d
semantic_memory: namespaces=["policies","controls","evidence-index"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced journal; snapshot each release tag
consistency: at-least-once (publish); exactly-once (co-sign per action_id)
idempotency: per Output Contracts

Decision and routing logic [Informative]

cosign_required = (action in {"isolate_host","disable_account"} and target in
CrownJewels) or requires_cosign = true
approve_required = change_risk >= 0.7 or diff touches policy_class = "privileged"
change_impact_score = $0.4blast_radius + 0.3control_criticality + 0.2*(1 -$
 $evidence_confidence) + 0.1*churn_rate$
routing = drafts→CI; builds→publish; co-signs→action_id channel; backpressure when
queue_depth > threshold

Model Risk Management [Informative]

continuous_validation: schedule=daily; eval_suite=[goldens, adversarial, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly ATT&CK-inspired probes
rollback_policy: if eval_drop >= 1.5 percentage points for 48 h → revert model_id to last
good; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who, what, why; evidence_refs; policy_refs; hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and
legal_hold

Incident Response Integration [Informative]

SIEM route: emit IRPolicyViolationEvent (OC-4) to sec.policy.incident; map severity
SOAR playbooks: open case, attach bundle diffs and evidence_refs

Change Impact Assessment [Informative]

compute change_impact_score; thresholds → staging only / HITL required / block
emit ChangeImpactReport (OC-5)

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6) with labels={helpful|neutral|harmful}
learning: update prompt_pack or rubric after governance review; never auto-train on
regulated evidence

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress and egress
legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: GitHub/GitLab Webhooks & REST; GRC REST/GraphQL
Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6

Safety and abuse prevention [Informative]

kill_switch on signature verification failure/anomaly; sandbox publish to staging on
missing attestation
blast_radius caps: <= 2 privileged policy changes/hour without secondary approval
cost/QPS limits per mission_id; alerts on breach

Testing and validation [Informative]

contract tests (derive from Schema Capsules); offline replay; red-team drills; drift checks
and rollback

Deployment and lifecycle [Informative]

scaling/HPA; canary and rollback; SBOM and attestations; signing requirements

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5; NIST SP 800-61 Rev. 2; NIST SP
800-137; NIST SP 800-207; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE
ATT&CK/D3FEND; SLSA; SPIFFE/SPIRE; CIS v8

MCP-Native Protocol Specification (A1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** GitHub/GitLab Webhooks & REST; GRC REST/GraphQL
- **Native Protocol(s) Produced:** Policy bundles (OPA bundle → OCI or Git); Co-signatures (gRPC metadata for protected actions)
- **MCP Context Fields:**
 - **Required:** mission_id; role="GovernancePolicyAgent"; intent="govern"; policy_refs=[...]; constraints=["policy_cosign"]; provenance.attestation (SLSA/SPIFFE + KID)
 - **Optional:** classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs must verify co-signature metadata before honoring protected actions.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

A2. Risk Analysis Agent

Agent Blueprint [Informative]

Purpose: Compute risk scores, recommend treatments (accept/mitigate/transfer/avoid), and drive prioritization for downstream remediation.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Findings from SIEM/EDR/CSPM** (REST/Kafka/OTel): detections, vulnerabilities, misconfigs, rule metadata, timestamps, evidence URIs.
- **CMDB / Asset Graph** (REST/GraphQL): business service, criticality, data class, RTO/RPO, ownership, region.
- **Threat Intelligence** (STIX/TAXII + CISA KEV/EPSS attributes): exploitability context, active exploitation.

Model training / knowledge (what the LLM relies on):

- Scoring & mapping rubrics (prompt pack or fine-tune): normalization of severities; mapping to NIST 800-53 (RA-3, RA-5, SI-2) and CIS Controls; dedup/merge heuristics.
- RAG sources: finding history, asset impact profiles, control catalog, KEV/EPSS tables (queried at run-time); **do not** embed regulated evidence—use evidence_refs to fetch on demand.
- Guardrails: read-only on SIEM/CMDB/TI; write only to GRC RiskAssessment endpoint and PriorityQueue topics; function-calling constrained to allowed scopes.

Decisions it makes (deterministic + model-assisted):

- Compute risk_score from normalized inputs; recommend treatment {accept | mitigate | transfer | avoid}.
- Escalation/HITL gate if action would auto-downgrade a **Critical** on CrownJewels, or proposes **accept** above policy threshold.
- Prioritization & routing: enqueue items to Patch/Vuln/Baseline agents with due_by and rationale; open GRC RiskAssessment records.
- De-duplication: merge overlapping findings to a single risk_id per asset/service.

Routing / where outputs go:

- **RiskAssessment** → GRC platform (REST/GraphQL).
- **PriorityQueue item** → Patch/Vuln/Baseline agents (Kafka/AMQP).
- Tickets/links → case or backlog systems when required by policy.

Automation scope vs. manual/HITL:

- Fully automated: ingestion, normalization, scoring, initial prioritization, RiskAssessment write, queueing for patch/vuln agents.

- **HITL required:**
 - Any “accept risk” recommendation above policy threshold.
 - Any downgrade of **Critical** severity on CrownJewels.
- Manual outside agent: risk appetite changes and weight policies; exception approvals for long-tail exposures.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **Findings from SIEM/EDR/CSPM (REST/Kafka/OTel)** — detections, vulnerabilities, misconfigs
2. **CMDB / Asset Graph (REST/GraphQL)** — criticality, business impact, data class, ownership
3. **Threat Intelligence (STIX/TAXII, KEV/EPSS attrs)** — exploitability context

Example: Consumed Protocol — Findings (SIEM/EDR/CSPM) [Informative]

Native payload

```
{
  "source": "siem",
  "finding_id": "FND-2025-08-15-0142",
  "kind": "detection",
  "rule": {"id": "okta-impossible-travel", "severity": "high"},
  "asset": {"asset_id": "srv-001", "ip": "10.2.14.5"},
  "mitre": ["TA0001", "T1078"],
  "first_seen": "2025-08-15T13:20:10Z",
  "last_seen": "2025-08-15T13:24:41Z",
  "related_cve": ["CVE-2025-12345"],
  "evidence_uri": "s3://siem/events/FND-2025-08-15-0142.json"
}
```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a2-risk-1111-2222-3333-4444",
    "thread_id": "uuid-finding-FND-2025-08-15-0142",
    "task_id": "uuid-a2-task-0001",
    "role": "RiskAnalysisAgent",
    "intent": "govern",
    "policy_refs": ["RA-5", "SI-2"],
    "decision_basis": {
      "evidence_refs": [
        "uri://siem/findings/FND-2025-08-15-0142",
        "s3://siem/events/FND-2025-08-15-0142.json"
      ],
      "confidence": 0.92,
      "explanation_ref": "uri://models/risk/scoring-v1#siem-edr-cspm-ingest"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/risk-analysis-agent",
      "signing_kid": "kid-a2-siem-01",
      "attestation_ref": "uri://slsa/attestations/risk-analysis@sha256:siem01"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

```
}
```

Example: Consumed Protocol — CMDB / Asset Graph (Criticality & Impact)

[Informative]

Native payload

```
{  
  "asset_id": "srv-001",  
  "business_service": "Payments",  
  "criticality": "CrownJewel",  
  "data_classification": ["PCI", "PII"],  
  "rto_minutes": 30,  
  "rpo_minutes": 15,  
  "owner_group": "payments.sre",  
  "region": "us-east-1"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-a2-risk-5555-6666-7777-8888",  
    "thread_id": "uuid-asset-srv-001-impact",  
    "task_id": "uuid-a2-task-0002",  
    "role": "RiskAnalysisAgent",  
    "intent": "govern",  
    "policy_refs": ["RA-3", "PM-5"],  
    "decision_basis": {  
      "evidence_refs": ["uri://cmdb/assets/srv-001/impact"],  
      "confidence": 0.97,  

```

```

    "explanation_ref": "uri://models/risk/impact-weighting-v1"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/grc/risk-analysis-agent",
    "signing_kid": "kid-a2-cmdb-02",
    "attestation_ref": "uri://slsa/attestations/risk-analysis@sha256:cmdb02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Threat Intelligence (STIX/TAXII) [Informative]
Native payload

```

{
  "type": "indicator",
  "id": "indicator--b3f1c3f6-1c9a-4b9c-bbdc-112233445566",
  "created": "2025-08-15T09:00:00Z",
  "pattern": "[vulnerability:name = 'CVE-2025-12345']",
  "labels": ["exploited-in-the-wild"],
  "x_epss_score": 0.87,
  "x_kev_listed": true
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

"mission_id": "uuid-a2-risk-9999-aaaa-bbbb-cccc",
"thread_id": "uuid-stix-CVE-2025-12345",
"task_id": "uuid-a2-task-0003",
"role": "RiskAnalysisAgent",
"intent": "govern",
"policy_refs": ["RA-3", "SI-4"],
"decision_basis": {
  "evidence_refs": ["uri://taxii/indicators/indicator--b3f1c3f6-1c9a-4b9c-bbdc-112233445566"],
  "confidence": 0.90,
  "explanation_ref": "uri://models/risk/exploitability-weighting-kev-epss"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/risk-analysis-agent",
  "signing_kid": "kid-a2-stix-03",
  "attestation_ref": "uri://slsa/attestations/risk-analysis@sha256:stix03"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- RiskAssessment records to GRC platforms (REST/GraphQL)
- PriorityQueue items to Patch/Vuln/Baseline agents (Kafka/AMQP)

MCP context (required) [Informative]

mission_id; role="RiskAnalysisAgent"; intent="govern"; decision_basis (evidence_refs, confidence, optional explanation_ref); policy_refs; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (C1–C3); constraints (e.g., "no_autoclose_without_review", "region:us-east-1"); legal_hold

Enforcement note [Informative]

GRC must enforce HITL token for **accept-risk** above threshold or Critical downgrades on CrownJewels; remediation consumers must honor idempotency keys and **due_by** semantics; no action if constraints include no_autoclose_without_review.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — analytical basis for risk-informed decisions.

Automation feasibility [Informative]

High (data fusion and scoring automatable; treatment exceptions may require HITL).

Output Contracts (merged) [Informative]

OC-1: RiskAssessment Publish (to GRC) [Informative]

- **Producer(s):** A2
- **Topic/Path:** POST /grc/risk_assessments (or GraphQL mutation createRiskAssessment)
- **Schema/Format:** RiskAssessment@1.1 (fields: risk_id, asset_id/service, risk_score, severity, recommended_treatment, rationale, controls_mapped, linked_findings, created_at)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-asset_id
- **Idempotency-Key:** sha256(asset_id, normalized_finding_set_hash, day_floor)
- **Ack/Nack:** HTTP 201 or GraphQL success; NACK = 4xx/5xx with error codes
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; open ticket if repeated NACK

- **Side-Effects:** link record into GRC evidence store; attach weight table reference
- **HITL Token:** required if recommended_treatment="accept" and risk_score >= policy.theta_accept **or** asset in CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.summary_ref
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RiskAssessment@1.1 | json_schema_uri=uri://schema/risk-assessment-1.1.json | sha256= | producers=A2 | consumers=GRC-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PriorityQueue Item (Patch/Vuln/Baseline agents) [Informative]

- **Producer(s):** A2
- **Topic/Path:** kafka://sec.priority.patch.v1 (or amqp://priority.patch.v1)
- **Schema/Format:** PriorityQueueItem@1.0 (fields: queue_id, asset_id, item_type, package_or_control, risk_score, due_by, rationale_ref, linked_findings, slo_target)
- **Classification:** C1 (upgrade to C2 if sensitive asset metadata present)
- **Delivery:** at-least-once
- **Ordering:** per-asset_id
- **Idempotency-Key:** sha256(asset_id, item_type, package_or_control, week_floor)
- **Ack/Nack:** broker ACK on publish; consumer ACK within 60s; NACK triggers retry/backoff
- **Timeouts/Retry:** consumer_ack<=60s; exp-backoff<=5x; requeue on timeout
- **Side-Effects:** create or link to remediation ticket; attach rationale_ref

- **HITL Token:** required if item would preempt SLAs for non-critical exposures on CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs
- **Retention/TTL:** 90 days (queue metadata), ticket links per ticketing policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When patch/vuln/baseline automation or PriorityQueue integration is present

schema_id=PriorityQueueItem@1.0 | json_schema_uri=uri://schema/priority-queue-item-1.0.json | sha256= | producers=A2 | consumers=PATCH-AGENT-01, VULN-AGENT-01, BASELINE-AGENT-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, enriching, scoring, writing_risk, enqueueing, awaiting_hitl, failed, closed }

transition(idle -> enriching) on new finding or intel update

transition(enriching -> scoring) when CMDB and TI fetched or timed out with defaults

transition(scoring -> writing_risk) when risk_score computed

transition(writing_risk -> enqueueing) on GRC ACK

transition(scoring -> awaiting_hitl) when recommended_treatment = "accept" and risk_score >= policy.theta_accept

transition(* -> failed) on validation error or repeated NACK

timeout(writing_risk, 30s) -> retry<=5 with exp backoff

idempotency_key:

- RiskAssessment: sha256(asset_id, normalized_finding_set_hash, day_floor)

- PriorityQueueItem: sha256(asset_id, item_type, package_or_control, week_floor)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 RiskAssessment	Required	Always	Core risk register in GRC
OC-2 PriorityQueueItem	Conditionally Required	Patch/Vuln/Baseline automation present or PriorityQueue enabled	Orchestrated remediation

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **HITL required:** accept-risk above threshold; downgrade **Critical** on CrownJewels.
- Manual outside agent: changes to risk appetite, weight tables, or regulatory exceptions.

SLOs and KPIs [Informative]

- RiskAssessmentLatency_p95 <= 30 s
- PrioritizationFreshness_24h >= 95 percent coverage
- FalsePriorityRate_7d <= 3 percent
- HITLDecisionTurnaround_p95 <= 2 h

Outputs index [Informative]

[OC-1 RiskAssessment], [OC-2 PriorityQueueItem]

Technical Implementation Details (A2) [Informative]

Model and training profile [Informative]

model_id=risk-text-model; temperature=0.2; max_tokens_out=800
prompt_pack_id=risk-scoring-v1 (normalization rules, treatment rubric, mapping to controls)
RAG: sources={finding history, asset impact profiles, control catalog, KEV/EPSS};
max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: optional; exclude regulated evidence; eval on calibration error and stability
guardrails: read-only on SIEM/CMDB/TI; write scopes limited to GRC risk and priority topics

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal of inputs→score→decision; ttl=180d
semantic_memory: namespaces=["findings","assets","ti","controls"]; embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced journal; daily snapshots of weight configs
consistency: at-least-once (RiskAssessment, PriorityQueueItem)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

$\text{risk_score} = w_{\text{sev}} \cdot \text{sev} + w_{\text{exposure}} \cdot \text{exposure} + w_{\text{exploit}} \cdot \text{exploit} + w_{\text{impact}} \cdot \text{impact}$
constraints: $w_{\text{sev}} + w_{\text{exposure}} + w_{\text{exploit}} + w_{\text{impact}} = 1.0$

where:

- sev = normalized severity 0..1 (CVSS base or analytic severity)
- exposure = external/internal attack surface 0..1
- exploit = exploitability signal 0..1 (KEV/EPSS/active exploitation)
- impact = business impact 0..1 (criticality, data class, RTO/RPO)

recommended_treatment rules:

- "mitigate" if risk_score ≥ 0.7
- "transfer" if risk_score in $[0.5, 0.7)$ and control gaps imply insurance route

- "avoid" if action can remove exposure with minimal impact
- "accept" if risk_score < policy.theta_accept and non-CrownJewels

routing: RiskAssessment → GRC; PriorityQueue → PATCH/VULN/BASELINE topics;
backpressure when queue depth > threshold

Model Risk Management [Informative]

kill_switch on abnormal score distribution shift; sandbox outputs when KEV/EPSS tables stale

red_team: adversarial inputs (label leakage, conflicting intel) → stable outputs

model drift: weekly calibration check; rollback if error > threshold

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: weights used; normalized inputs; evidence_refs; policy_refs; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit SIEM case linkage in GRC record; attach finding/evidence_refs for triage playbooks

Change Impact Assessment [Informative]

(optional) compare risk deltas across policy changes; emit report to GRC if enabled

Stakeholder Feedback Loop [Informative]

(optional) capture reviewer labels {helpful|neutral|harmful}; incorporate via governance-reviewed rubric updates (never auto-train on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress

legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: SIEM/EDR/CSPM findings; CMDB/Asset Graph; STIX/TAXII intel

Produces: OC-1 RiskAssessment; OC-2 PriorityQueueItem

Safety and abuse prevention [Informative]

blast_radius caps: limit per-minute queue inserts per service; guard against queue floods

cost/QPS controls on upstream APIs

Testing and validation [Informative]

contract tests (schema conformance, idempotency, ack windows); offline replay with historical incidents (AUC/precision@k on prioritization)

Deployment and lifecycle [Informative]

HPA on ingest rate; shard by asset_id; canary score distribution monitor; rollback on divergence

SBOM + SLSA/in-toto attestations; signed outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (RA-3, RA-5, SI-2); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CISA KEV; EPSS

MCP-Native Protocol Specification (A2) [Normative]

- **Native Protocol(s) Consumed:** SIEM/EDR/CSPM (REST/Kafka/OTel); CMDB/Asset Graph (REST/GraphQL); STIX/TAXII (+ KEV/EPSS attrs)
- **Native Protocol(s) Produced:** RiskAssessment (REST/GraphQL to GRC); PriorityQueueItem (Kafka/AMQP to remediation agents)
- **MCP Context Fields:**
 - **Required:** mission_id; role="RiskAnalysisAgent"; intent="govern"; decision_basis (evidence_refs, confidence, optional explanation_ref); policy_refs; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification (C1–C3); constraints; legal_hold
- **Enforcement Note:** GRC must enforce HITL tokens for above-threshold acceptances or Critical downgrades on CrownJewels; remediation consumers must verify idempotency and constraint flags prior to action.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.

- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

A3. Compliance Auditor Agent

Agent Blueprint [Informative]

Purpose: Map controls to evidence across systems, evaluate coverage/conformance, and emit gap findings with audit-ready trails.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Policy Repository** (Git/REST): policies, standards, control mappings, thresholds (coverage, retention, required event classes).
- **SIEM Evidence** (REST/OTel/Kafka): `control_coverage_percent`, `retention_days`, observed event classes.
- **EDR/Posture Evidence** (REST/gRPC): fleet coverage, sensor health, `not_reporting` counts.
- **CSPM Evidence** (REST/JSON): cloud control checks and mappings (CIS/NIST).
- **IAM/IdP Evidence** (REST/JSON or Syslog): MFA/passwordless coverage, dormant accounts, SoD violations.

Model training / knowledge (what the LLM relies on):

- Mapping and wording rubric (prompt pack): how to read policy YAML, map evidence to controls (e.g., AU-12, CM-6, IA-2), and phrase regulator-ready gap statements.
- RAG sources: policy repo, evidence catalogs (OTel metrics, CSPM checks), IAM posture snapshots, EDR fleet health, mapping handbook. Do not embed regulated evidence in training—use `evidence_refs` at run time.
- Guardrails: read-only on evidence systems; write only to ticketing/GRC and evidence-manifest registry; function calls restricted to approved scopes.

Decisions it makes (deterministic + model-assisted):

- Conformance evaluation against policy thresholds (coverage percent, retention days, required event classes, sensor health).
- Gap classification (severity, owner_group, due_date) and ticket emission with linked evidence.
- EvidenceManifest creation for defensible chains (URIs + content digests).
- Optional ComplianceStatusUpdate events for dashboards.
- Classification tagging (C3) for regulated evidence and legal_hold toggles when under counsel.

Routing / where outputs go:

- **ComplianceGap** tickets → ServiceNow/Jira/Archer (or GRC).
- **AuditTrailRecord / EvidenceManifest** → object store + evidence index.
- **ComplianceStatusUpdate** (optional) → Kafka/AMQP for analytics.

Automation scope vs. manual/HITL:

- Fully automated: policy/evidence parsing, threshold checks, gap ticket creation, evidence manifesting, status events.
- **HITL required:**
 - Downgrading a High gap to Medium/Low on CrownJewels.
 - Approving waivers/exceptions that bypass thresholds.
- Manual outside agent: drafting regulator-facing narrative where jurisdiction-specific language is required; selecting compensating controls when none are codified.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **Policy Repository (Git/REST)** — authoritative policies/standards and control mappings
2. **SIEM Evidence (REST/OTel/Kafka)** — logging coverage, retention, event classes

3. **EDR/Posture Evidence (REST/gRPC)** — endpoint coverage/health vs. baselines
4. **CSPM Evidence (REST/JSON)** — cloud control checks (CIS/NIST mappings)
5. **IAM/IdP Evidence (REST/JSON or Syslog)** — MFA/passwordless, SoD, dormant accounts

Example: Consumed Protocol — Policy Repository (Git/REST) [Informative]
Native YAML (excerpt)

policy_id: AU-12-endpoint-logging

version: "1.3"

title: "Endpoint Logging Standard"

controls: ["AU-12", "AU-6"]

requirements:

min_coverage_percent: 98.0

min_retention_days: 365

required_event_classes: ["process_creation", "auth_failure", "dns_query"]

evidence_sources:

- siem: otel.metrics.control_coverage_percent

- edr: sensor_health

owners: ["sec.logging"]

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-a3-pol-1111-2222-3333-4444",  
    "thread_id": "uuid-policy-AU-12-endpoint-logging@1.3",  
    "task_id": "uuid-a3-task-0001",  
    "role": "ComplianceAuditorAgent",
```

```

"intent": "govern",
"policy_refs": ["AU-12","AU-6"],
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/compliance-auditor-agent",
  "signing_kid": "kid-git-a3-01",
  "attestation_ref": "uri://slsa/attestations/compliance-auditor@sha256:git01"
},
"classification": "C2",
"legal_hold": false,
"decision_basis": {
  "evidence_refs": ["uri://git/sec/policies/AU-12-endpoint-logging.yaml@v1.3"],
  "confidence": 0.99,
  "explanation_ref": "uri://kb/compliance/mapping-method#policy-yaml"
}
},
"native_payload": "policy_id: AU-12-endpoint-logging\nversion: \"1.3\"..."
}

```

Example: Consumed Protocol — SIEM Evidence (REST/OTel/Kafka) [Informative]
Native payload (OTel metric)

```

{
  "resource": {"service.name":"siem-collector","service.namespace":"secops"},
  "metric": {
    "name":"control_coverage_percent",
    "labels":{"control":"AU-12","platform":"endpoint"},
    "type":"gauge",
    "value":98.7,
    "timestamp":"2025-08-15T12:05:00Z"
  }
}

```

```

    },
    "retention_days":390,

    "event_classes_seen":["process_creation","auth_failure","dns_query","network_connect
"]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a3-siem-5555-6666-7777-8888",
    "thread_id": "uuid-otel-AU-12-coverage",
    "task_id": "uuid-a3-task-0002",
    "role": "ComplianceAuditorAgent",
    "intent": "govern",
    "policy_refs": ["AU-12"],
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/compliance-auditor-agent",
      "signing_kid": "kid-otel-a3-02",
      "attestation_ref": "uri://slsa/attestations/compliance-auditor@sha256:otel02"
    },
    "classification": "C3",
    "legal_hold": false,
    "decision_basis": {
      "evidence_refs": ["uri://otel/metrics/siem-collector/control_coverage_percent/2025-
08-15T12:05:00Z"],
      "confidence": 0.98,

```

```

    "explanation_ref": "uri://kb/compliance/au12-evidence-eval#coverage-retention"
  }
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — EDR/Posture Evidence (REST/gRPC) [Informative]
Native payload

```

{"fleet": "prod-endpoints", "required_policy": "Prod-Servers", "coverage_percent": 96.9,
 "unhealthy": 21, "not_reporting_24h": 9, "sampled_at": "2025-08-15T12:10:30Z"}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a3-edr-9999-aaaa-bbbb-cccc",
    "thread_id": "uuid-edr-coverage-prod-endpoints",
    "task_id": "uuid-a3-task-0003",
    "role": "ComplianceAuditorAgent",
    "intent": "govern",
    "policy_refs": ["CM-6", "SI-3"],
    "provenance": {"producer_spiffe": "spiffe://enterprise/grc/compliance-auditor-agent",
      "signing_kid": "kid-edr-a3-03", "attestation_ref": "uri://slsa/attestations/compliance-auditor@sha256:edr03"},
    "classification": "C3", "legal_hold": false,
    "decision_basis": {"evidence_refs": ["uri://edr/fleets/prod-endpoints/coverage/2025-08-15T12:10:30Z"],
      "confidence": 0.96, "explanation_ref": "uri://kb/compliance/endpoint-coverage-thresholds"}
  },
}

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```
"native_payload": { ... }  
}
```

Example: Consumed Protocol — CSPM Evidence (REST/JSON) [Informative]

Native payload

```
{  
  "check_id": "cis_aws_3_1", "title": "Ensure S3 buckets restrict public access",  
  "result": "fail", "affected_resources": [{"arn": "arn:aws:s3:::logs-prod",  
    "reason": "BlockPublicAcls=false"}],  
  "control_mappings": ["SC-7", "CM-6"], "evaluated_at": "2025-08-15T11:58:00Z"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-a3-cspm-abcd-ef01-2345-6789",  
    "thread_id": "uuid-cspm-cis_aws_3_1",  
    "task_id": "uuid-a3-task-0004",  
    "role": "ComplianceAuditorAgent", "intent": "govern", "policy_refs": ["SC-7", "CM-6"],  
    "provenance": {"producer_spiffe": "spiffe://enterprise/grc/compliance-auditor-agent",  
      "signing_kid": "kid-cspm-a3-04", "attestation_ref": "uri://slsa/attestations/compliance-auditor@sha256:cspm04"},  
    "classification": "C2", "legal_hold": false,  
    "decision_basis": {"evidence_refs": ["uri://cspm/checks/cis_aws_3_1/2025-08-15T11:58:00Z"],  
      "confidence": 0.94, "explanation_ref": "uri://kb/compliance/cspm-check-mapping#cis_aws_3_1"}  
  },  
  "native_payload": { ... }
```

```
}
```

Example: Consumed Protocol — IAM/IdP Evidence (REST/JSON or Syslog)

[Informative]

Native payload

```
{"org":"example-okta","mfa_coverage_percent":97.2,"passwordless_users":61.5,

"dormant_accounts_90d":134,"sod_violations":[{"user":"E100337","conflict":"FIN_AP_R
EQUESTOR + FIN_AP_APPROVER"}],

"snapshot":"2025-08-15T12:12:40Z"}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version":"0.9",
    "mission_id":"uuid-a3-iam-1357-2468-aaaa-bbbb",
    "thread_id":"uuid-iam-org-example-okta",
    "task_id":"uuid-a3-task-0005",
    "role":"ComplianceAuditorAgent","intent":"govern",
    "policy_refs":["IA-2","IA-5","AC-5","AC-2"],
    "provenance":{"producer_spiffe":"spiffe://enterprise/grc/compliance-auditor-agent",
      "signing_kid":"kid-iam-a3-05","attestation_ref":"uri://slsa/attestations/compliance-
auditor@sha256:iam05"},
    "classification":"C3","legal_hold":false,
    "decision_basis":{"evidence_refs":["uri://idp/orgs/example-okta/security-posture/2025-
08-15T12:12:40Z"],
      "confidence":0.95,"explanation_ref":"uri://kb/compliance/mfa-sod-coverage"}
  },
  "native_payload": { ... }
}
```

Outputs (native) [Informative]

- ComplianceGap tickets to ticketing/GRC.
- AuditTrailRecord / EvidenceManifest (URIs + hashes) for defensible chains.
- Optional: ComplianceStatusUpdate events for dashboards.

MCP context (required) [Informative]

mission_id; role="ComplianceAuditorAgent"; intent="govern"; policy_refs; provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

classification (tag regulated evidence as C3); legal_hold; decision_basis (evidence_refs, confidence, explanation_ref).

Enforcement note [Informative]

Ticketing/GRC and evidence registry PEPs must enforce:

- HITL token present for waiver approvals or any severity downgrade on CrownJewels.
- EvidenceManifest items are content-addressed with verified digests; reject unsigned or mismatched hashes.
- No purge when legal_hold=true.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — evidence-driven assurance of control effectiveness.

Automation feasibility [Informative]

High (collection, mapping, evaluation, ticketing, manifesting are automatable; regulator-specific prose may need HITL).

Output Contracts (merged) [Informative]

OC-1: ComplianceGap Ticket (to Ticketing/GRC) [Informative]

- **Producer(s):** A3
- **Topic/Path:** POST /tickets/compliance_gap (or GraphQL: createComplianceGap)

- **Schema/Format:** ComplianceGap@1.1 (gap_id, control_id, title, severity, description, owner_group, due_date, evidence[], recommendation, regulatory_tags[])
- **Classification:** C3 (may reference PII in evidence links)
- **Delivery:** at-least-once
- **Ordering:** per control_id and asset_or_scope
- **Idempotency-Key:** sha256(control_id, asset_or_scope, day_floor)
- **Ack/Nack:** 201 Created (or GraphQL success); NACK = 4xx/5xx with error codes
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; open escalation ticket on repeated NACK
- **Side-Effects:** link EvidenceManifest; subscribe owner_group watchers
- **HITL Token:** required if request_waiver=true or severity_downgrade on CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs
- **Retention/TTL:** 7 years (or per legal hold)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ComplianceGap@1.1 | json_schema_uri=uri://schema/compliance-gap-1.1.json | sha256= | producers=A3 | consumers=SNOW-01,JIRA-01,ARCHER-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EvidenceManifest (to Evidence Registry) [Informative]

- **Producer(s):** A3
- **Topic/Path:** POST /evidence/manifests and object store put (e.g., s3://audits/...)
- **Schema/Format:** EvidenceManifest@1.0 (manifest_id, items[{uri, sha256}], signed_by, created_at)
- **Classification:** C3

- **Delivery:** exactly-once (content-addressed; idempotent by digest)
- **Ordering:** per manifest_id
- **Idempotency-Key:** sha256(sorted_item_digests)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; on final NACK → flag legal_hold and alert
- **Side-Effects:** register manifest in evidence index; sign and timestamp
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs
- **Retention/TTL:** 7 years; indefinite when legal_hold=true

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EvidenceManifest@1.0 | json_schema_uri=uri://schema/evidence-manifest-1.0.json | sha256= | producers=A3 | consumers=EVID-REG-01,AUDIT-PORTAL-01 | accepts=1.0–1.0

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-3: ComplianceStatusUpdate Event (dashboards) [Informative, optional]

- **Producer(s):** A3
- **Topic/Path:** kafka://compliance.status.v1 (or amqp://compliance.status.v1)
- **Schema/Format:** ComplianceStatusUpdate@1.0 (control_id, scope, status, score, ts, refs[])
- **Classification:** C1 (upgrade to C2 if scope reveals sensitive asset details)
- **Delivery:** at-least-once
- **Ordering:** per control_id and scope
- **Idempotency-Key:** sha256(control_id, scope, ts_floor_5m)
- **Ack/Nack:** broker ACK; consumer ACK<=60s; NACK triggers retry/backoff

- **Timeouts/Retry:** consumer_ack<=60s; exp-backoff<=5x
- **Side-Effects:** none
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs
- **Retention/TTL:** 180 days (event store)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When dashboards/analytics integration is present

schema_id=ComplianceStatusUpdate@1.0 |

json_schema_uri=uri://schema/compliance-status-1.0.json | sha256= | producers=A3 |

consumers=COMPL-DASH-01 | accepts=1.0–1.0

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting, mapping, evaluating, emitting_gap, writing_manifest, notifying, awaiting_hitl, failed, closed }

transition(idle -> ingesting) on new policy/evidence input

transition(ingesting -> mapping) when policy YAML parsed and evidence sources resolved

transition(mapping -> evaluating) when metrics loaded or timed out with defaults

transition(evaluating -> emitting_gap) when thresholds violated

transition(evaluating -> writing_manifest) when evidence set completes

transition(emitting_gap -> notifying) when ticket ACK received

transition(evaluating -> awaiting_hitl) when waiver requested or severity_downgrade on CrownJewels

transition(* -> failed) on validation error or repeated NACK

timeout(emitting_gap, 30s) -> retry<=5 with exp backoff

idempotency_key:

- ComplianceGap: sha256(control_id, asset_or_scope, day_floor)
- EvidenceManifest: sha256(sorted_item_digests)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ComplianceGap	Required	Always	Drive remediation accountability
OC-2 EvidenceManifest	Required	Always	Defensible audit chain
OC-3 ComplianceStatusUpdate	Optional	Dashboards/analytics integration present	Compliance visibility

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **HITL required:** waiver approvals; severity downgrade on CrownJewels; deletion of gaps that still have open evidence.
- **Manual outside agent:** regulator-specific prose; compensating control selection when uncoded.

SLOs and KPIs [Informative]

- GapDetectionLatency_p95 <= 5 min
- EvidenceManifestCompleteness = 100 percent for emitted gaps

- FalseGapRate_30d <= 1 percent
- HITLDecisionTurnaround_p95 <= 4 h

Outputs index [Informative]

[OC-1 ComplianceGap], [OC-2 EvidenceManifest], [OC-3 ComplianceStatusUpdate]

Technical Implementation Details (A3) [Informative]

Model and training profile [Informative]

model_id=compliance-text-model; temperature=0.2; max_tokens_out=800
 prompt_pack_id=compliance-mapping-v1 (policy YAML parsing, threshold logic, regulator wording rubric)
 RAG: sources={policy repo, OTEL metrics, EDR fleet health, CSPM checks, IAM posture, mapping handbook}; max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: optional; exclude regulated evidence; evaluate on mapping accuracy and statement correctness
 guardrails: read-only on evidence systems; write scopes limited to ticket/GRC and evidence registry

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal of policy→evidence→decision; ttl=365d
 semantic_memory: namespaces=["policies", "evidence", "mappings"]; embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced journal; manifests are content-addressed; daily snapshots of threshold configs
 consistency: at-least-once (gaps, status); exactly-once (manifests via digest)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

coverage_gap = max(0, required_coverage_percent - observed_coverage_percent)
 retention_gap_days = max(0, required_retention_days - observed_retention_days)
 missing_event_classes = required_event_classes - event_classes_seen
 missing_eclases_norm = len(missing_event_classes) / max(1, len(required_event_classes))
 edr_health_gap = max(0, required_coverage_percent - edr.coverage_percent)

$\text{conformance_score} = 1 - (\text{w_cov} * \text{coverage_gap_norm} + \text{w_ret} * \text{retention_gap_norm} + \text{w_eclass} * \text{missing_eclasses_norm} + \text{w_edr} * \text{edr_health_gap_norm})$

severity = "High" if conformance_score < 0.7

else "Medium" if conformance_score < 0.85

else "Low"

routing: gaps→ticketing; manifests→evidence registry; status→events; backpressure when queue depth > threshold

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, edge cases]

thresholds: mapping_accuracy_7d >= 99.0 percent → auto_HITL if below

red_team_cycle: monthly contradictory/omitted evidence drills

rollback_policy: if mapping_accuracy_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: policy_yaml_ref; thresholds; observed metrics; evidence_refs; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

on High gaps tied to active incidents, attach SIEM case IDs to the ticket and EvidenceManifest

Change Impact Assessment [Informative]

(optional) recompute conformance_score deltas after policy updates; include in ticket comments

Stakeholder Feedback Loop [Informative]

(optional) reviewer labels {valid_gap|false_positive|needs_more_evidence}; feed into rubric after governance review

Data Sovereignty and Legal Hold [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress
legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: Policy Git/REST; SIEM OTel/Kafka; EDR gRPC/REST; CSPM REST/JSON; IAM REST/JSON/Syslog

Produces: OC-1 ComplianceGap; OC-2 EvidenceManifest; OC-3 ComplianceStatusUpdate

Safety and abuse prevention [Informative]

classification defaults to C3 for evidence; auto-tag legal_hold when counsel flag present
blast_radius caps: limit gap creation per control per hour; dedupe same-day gaps
cost/QPS rate-limits on upstream evidence pulls

Testing and validation [Informative]

contract tests (schema conformance, idempotency, ack windows)
offline replay with historical audit cycles; acceptance on precision/recall of gap detection
red-team: contradictory evidence and missing files → expect conservative gaps or HITL

Deployment and lifecycle [Informative]

HPA on ingest rate; shard by control_id or asset scope
canary conformance_score distributions; rollback on divergence
SBOM + SLSA/in-toto attestations; sign manifests and ticket payloads

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CA-2, CA-7, AU-6/AU-11/AU-12, CM-6, IA-2/IA-5, AC-2/AC-5); NIST SP 800-137; NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK/D3FEND; CIS Benchmarks / CIS Controls v8; SCAP (XCCDF/OVAL); STIX 2.1 / TAXII 2.x

MCP-Native Protocol Specification (A3) [Normative]

- **Native Protocol(s) Consumed:** Policy Git/REST; SIEM OTel/Kafka; EDR gRPC/REST; CSPM REST/JSON; IAM REST/JSON/Syslog
- **Native Protocol(s) Produced:** ComplianceGap (ticket/GRC); EvidenceManifest (registry); ComplianceStatusUpdate (Kafka/AMQP)

- **MCP Context Fields:**
 - **Required:** mission_id; role="ComplianceAuditorAgent"; intent="govern"; policy_refs; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; legal_hold; decision_basis (evidence_refs, confidence, explanation_ref)
- **Enforcement Note:** PEPs must require HITL tokens for waiver approvals and any CrownJewels severity downgrades; evidence registry must verify content digests and signatures; legal_hold forbids purge.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

A4. Policy Authoring Agent

Agent Blueprint [Informative]

Purpose: Generate and update security standards, baselines, and playbooks from incident RCAs, red/purple-team results, and regulatory updates; submit policy/baseline PRs with full rationale traceability.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **RCA Findings Repository** (REST/Markdown/JSON): incident postmortems, failed controls, artifacts/diffs.
- **Red/Purple-Team Results** (REST/JSON): ATT&CK techniques, failed controls, evidence, recommendations.
- **Regulatory/Standards Update Feeds** (RSS/Atom/REST): NIST/CIS/PCI/ISO errata, new versions, effective dates.

Model training / knowledge (what the LLM relies on):

- Drafting & mapping rubric (prompt pack): convert RCAs + exercise findings + standards deltas into concrete policy/baseline diffs with citations.
- RAG sources: policy repo history, baseline library, mapping handbook (800-53/CIS/PCI/ISO), RCA archives, red-team findings, standards bulletins. **Do not** embed regulated evidence—use `evidence_refs` at run time.
- Guardrails: write only to feature branches or artifact buckets; cannot push to main or publish registries; function calls scoped to Git/object storage only.

Decisions it makes (deterministic + model-assisted):

- **Change selection:** which standards/baselines/playbooks must be updated and how (line-level diffs).
- **Update priority & scope** using a transparent score; drafts PRs and baseline templates.
- **Traceability:** creates or links a **RationaleRecord** and sets `explanation_ref` for every change.
- **Classification:** tag artifacts **C2** by default; elevate to **C3** if regulated content appears.

Routing / where outputs go:

- **Policy PRs** → Git (feature branch) with linked RCA/RT/REG references.
- **Baseline Templates** → artifact store (YAML/OPA/SCAP) for downstream enforcement/testing.
- **RationaleRecord** → evidence registry (content-addressed), referenced by `explanation_ref`.

Automation scope vs. manual/HITL:

- Fully automated: draft diffs, link evidence, open PRs, generate baseline templates, create RationaleRecord.
- **HITL required:**
 - Merges that weaken controls or alter CrownJewels baselines.
 - Any removal of compensating controls or downgrade of requirements.
- Manual outside agent: final regulator-mandated prose; cross-domain coordination when changes affect non-security SLAs.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **RCA Findings Repository (REST/Markdown/JSON)** — post-incident/root-cause analyses
2. **Red/Purple-Team Results (REST/JSON)** — ATT&CK-mapped findings, failed controls
3. **Regulatory/Standards Feeds (RSS/Atom/REST)** — NIST/CIS/PCI/ISO errata and versions

Example: Consumed Protocol — RCA Findings Repository [Informative]

Native payload

```
{
  "rca_id": "RCA-2025-0815-0021",
  "incident_id": "INC-45877",
  "summary": "Privilege escalation via stale sudoers entry",
  "root_causes": [
    {"id": "RC-1", "text": "Baseline drift not detected for sudoers on prod Linux"},
    {"id": "RC-2", "text": "Exemption auto-renewed without owner sign-off"}
  ],
  "failed_controls": ["CM-6", "AC-5"],
  "recommended_changes": [
    "Require owner co-sign on exemption renewals",
    "Enforce noexec,nodev,nosuid on /tmp in baseline L1"
  ],
  "artifacts": [
    "s3://rca/INC-45877/timeline.md",
    "s3://rca/INC-45877/evidence/sudoers.diff"
  ],
}
```

```

    "created_at": "2025-08-15T10:40:00Z"
  }
  MCP-wrapped payload
  {
    "mcp_context": {
      "mcp_version": "0.9",
      "mission_id": "INC-45877",
      "thread_id": "uuid-rca-RCA-2025-0815-0021",
      "task_id": "uuid-a4-task-rca-01",
      "role": "PolicyAuthoringAgent",
      "intent": "govern",
      "policy_refs": ["CM-6", "AC-5"],
      "explanation_ref": "uri://kb/policy/updates/INC-45877#rationale",
      "decision_basis": {
        "evidence_refs": [
          "uri://rca/RCA-2025-0815-0021",
          "s3://rca/INC-45877/evidence/sudoers.diff"
        ],
        "confidence": 0.94
      },
      "provenance": {
        "producer_spiffe": "spiffe://enterprise/grc/policy-authoring-agent",
        "signing_kid": "kid-a4-rca-01",
        "attestation_ref": "uri://slsa/attestations/policy-authoring@sha256:rca01"
      },
      "classification": "C2",

```

```
    "legal_hold": false
  },
  "native_payload": { ... }
}
```

Example: Consumed Protocol — Red/Purple-Team Results [Informative]

Native payload

```
{
  "exercise_id": "RT-2025-Q3-01",
  "technique": "T1548.003 - Sudo and Sudo Caching",
  "asset_scope": ["linux-prod"],
  "finding_id": "RTF-117",
  "severity": "High",
  "observations": [
    "Sudoers rule allowed shell escalation for svc_backup",
    "No MFA required for sudo on 17% of hosts"
  ],
  "failed_controls": ["AC-6", "IA-2", "CM-6"],
  "recommendations": [
    "Constrain sudoers with exact command allowlists",
    "Step-up MFA for sudo on crown jewels"
  ],
  "evidence_uri": "s3://redteam/2025Q3/findings/RTF-117.json",
  "timestamp": "2025-08-12T19:15:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
```

```

"mcp_version": "0.9",
"mission_id": "INC-45877",
"thread_id": "uuid-redteam-RTF-117",
"task_id": "uuid-a4-task-rt-02",
"role": "PolicyAuthoringAgent",
"intent": "govern",
"policy_refs": ["AC-6", "IA-2", "CM-6"],
"explanation_ref": "uri://kb/policy/updates/INC-45877#redteam",
"decision_basis": {
  "evidence_refs": ["s3://redteam/2025Q3/findings/RTF-117.json"],
  "confidence": 0.91
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/policy-authoring-agent",
  "signing_kid": "kid-a4-rt-02",
  "attestation_ref": "uri://slsa/attestations/policy-authoring@sha256:rt02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Regulatory/Standards Feeds [Informative]

Native payload

```

{
  "source": "CIS",
  "artifact": "CIS Linux Benchmark",

```

```

"version_from": "1.0.0",
"version_to": "1.1.0",
"effective_date": "2025-09-01",
"changes": [
  {"id": "5.2.8", "change": "Update PermitRootLogin guidance to prohibit 'prohibit-
password' exceptions"},
  {"id": "1.1.1", "change": "Clarify /tmp mount options for containers"}
],
"url": "https://example.org/cis/linux/1.1.0/notes"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "INC-45877",
    "thread_id": "uuid-stds-cis-linux-1-1-0",
    "task_id": "uuid-a4-task-reg-03",
    "role": "PolicyAuthoringAgent",
    "intent": "govern",
    "policy_refs": ["CM-6", "IA-2"],
    "explanation_ref": "uri://kb/policy/updates/INC-45877#regulatory-alignment",
    "decision_basis": {
      "evidence_refs": ["uri://regs/cis/linux/1.1.0/notes"],
      "confidence": 0.90
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/policy-authoring-agent",

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    "signing_kid": "kid-a4-reg-03",
    "attestation_ref": "uri://slsa/attestations/policy-authoring@sha256:reg03"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- Policy PRs to Git (standards/playbooks).
- Baseline Template artifacts (YAML / OPA / SCAP) for downstream enforcement.
- RationaleRecord (traceability) to evidence registry; referenced by explanation_ref.

MCP context (required) [Informative]

mission_id (links to motivating incident[s]); role="PolicyAuthoringAgent"; intent="govern"; explanation_ref (URI to rationale/trace doc); provenance.attestation (SPIFFE identity, signing KID).

MCP context (optional) [Informative]

policy_refs (800-53/CIS mappings touched); classification (C2, elevate to C3 if regulated content); decision_basis (evidence_refs, confidence); legal_hold.

Enforcement note [Informative]

PR merge and baseline registry PEPs must require HITL tokens for control-weakening changes or any CrownJewels baseline edits; artifact registry must verify signatures and content digests; legal_hold forbids purge.

NIST SP 800-160v2 linkage [Informative]

Develop & Implement (derive/up-rev requirements from evidence and lessons learned); Maintain (continuous policy adaptation).

Automation feasibility [Informative]

High for drafting/templating and PR plumbing; HITL review/approval for final merges.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Output Contracts (merged) [Informative]

OC-1: Policy Pull Request (to Git) [Informative]

- **Producer(s):** A4
- **Topic/Path:** POST /repos/<org>/sec/policies/pulls (branch=feature/<mission_id>-<slug>)
- **Schema/Format:** PolicyPR@1.0 (repository, branch, title, changes[{path, op}], links{rca, redteam, reg_update})
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per repository + branch
- **Idempotency-Key:** sha256(repo, branch, diff_hash)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx with error codes
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; open ticket on repeated NACK
- **Side-Effects:** link PR to **RationaleRecord**; request reviews from CODEOWNERS; label policy-update
- **HITL Token:** required to merge PRs that weaken controls or touch CrownJewels baselines
- **Observability:** trace_id, mission_id, policy_refs, explanation_ref, evidence_refs
- **Retention/TTL:** repo history policy (>= 7 years for audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PolicyPR@1.0 | json_schema_uri=uri://schema/policy-pr-1.0.json | sha256= | producers=A4 | consumers=Git-Repo-01 | accepts=1.0–1.0

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: Baseline Template Artifact (YAML / OPA / SCAP) [Informative]

- **Producer(s):** A4

- **Topic/Path:** s3://policy-artifacts/baselines/<org>/<id>/<version>/ or oci://baseline-registry/<org>/<id>:<version>
- **Schema/Format:** BaselineTemplate@1.0 (id, version, rules[], metadata.derived_from[])
- **Classification:** C2 (elevate to C3 if regulated data embedded)
- **Delivery:** exactly-once (content-addressed by digest)
- **Ordering:** per id + version
- **Idempotency-Key:** sha256(id, version, content_digest)
- **Ack/Nack:** 201 Created or ETag match; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on final NACK → alert + set legal_hold flag
- **Side-Effects:** register artifact in baseline index; run schema/OPA/SCAP validation suite
- **HITL Token:** required if rules remove/relax a required control for CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, explanation_ref, evidence_refs
- **Retention/TTL:** 7 years (artifacts), indefinite if referenced by released policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When baseline artifacts are used or baseline changes are included in the mission

schema_id=BaselineTemplate@1.0 | json_schema_uri=uri://schema/baseline-template-1.0.json | sha256= | producers=A4 | consumers=Baseline-Test-01, Policy-Registry-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

OC-3: PolicyUpdate RationaleRecord (to Evidence Registry) [Informative]

- **Producer(s):** A4
- **Topic/Path:** POST /evidence/rationale (and object store put)
- **Schema/Format:** RationaleRecord@1.0 (rationale_id, mission_id, refs[RCA, RT, REG], summary, weights, decisions)

- **Classification:** C2 (may reference C3 evidence via URIs)
- **Delivery:** exactly-once (content-addressed)
- **Ordering:** per mission_id
- **Idempotency-Key:** sha256(mission_id, refs_digest)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x
- **Side-Effects:** set/refresh explanation_ref on related PRs and templates
- **HITL Token:** none
- **Observability:** trace_id, mission_id, evidence_refs
- **Retention/TTL:** 7 years; indefinite under legal_hold

Schema Capsule (OC-3) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RationaleRecord@1.0 | json_schema_uri=uri://schema/rationale-record-1.0.json | sha256= | producers=A4 | consumers=Evidence-Registry-01 | accepts=1.0-1.0

Conformance: This capsule and the corresponding MCP schema define testable requirements.

State machine (concise) [Informative]

states = { idle, analyzing_inputs, drafting, generating_diffs, creating_pr,
generating_template,
writing_rationale, awaiting_review, failed, closed }

transition(idle -> analyzing_inputs) on RCA/RT/REG update

transition(analyzing_inputs -> drafting) when sources parsed and mapped

transition(drafting -> generating_diffs) when target files/rules selected

transition(generating_diffs -> creating_pr) when diff validated

transition(drafting -> generating_template) if baseline changes required

transition(* -> writing_rationale) before emitting outputs to ensure explanation_ref exists
transition(creating_pr -> awaiting_review) on PR ACK
transition(generating_template -> awaiting_review) on artifact ACK
transition(* -> failed) on validation error or repeated NACK

timeout(creating_pr, 30s) -> retry<=5 with exp backoff

idempotency_key:

- PolicyPR: sha256(repo, branch, diff_hash)
- BaselineTemplate: sha256(id, version, content_digest)
- RationaleRecord: sha256(mission_id, refs_digest)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PolicyPR	Required	Always	Core policy/baseline change vehicle
OC-2 BaselineTemplate	Conditionally Required	Baseline artifacts used or baseline changes in mission	Downstream enforcement/test automation
OC-3 RationaleRecord	Required	Always	Traceability and explainability

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- **HITL required:** merges that weaken controls; any baseline change affecting CrownJewels; removal of compensating controls.
- **Manual outside agent:** regulator-mandated prose; cross-team sign-off when SLAs are impacted.

SLOs and KPIs [Informative]

- `PRCreationLatency_p95` <= 30 s
- `TemplateValidationPassRate` >= 99 percent
- `RationaleCompleteness` = 100 percent for emitted PRs/templates
- `HITLDecisionTurnaround_p95` <= 24 h

Outputs index [Informative]

[OC-1 PolicyPR], [OC-2 BaselineTemplate], [OC-3 RationaleRecord]

Technical Implementation Details (A4) [Informative]

Model and training profile [Informative]

`model_id=policy-author-text-model`; `temperature=0.2`; `max_tokens_out=800`
`prompt_pack_id=policy-author-v1` (diff drafting patterns, mapping rubric, citation policy)
RAG: `sources={policy repo history, baseline library, mapping handbook, RCA archive, RT findings, standards bulletins}`; `max_docs=10`; `min_similarity=0.78`; citations required
`fine_tuning/adapters: optional`; exclude regulated evidence; eval on diff correctness and citation coverage
`guardrails: write-scoped tokens; deny push to main; deny registry publish; file-path allowlists`

Memory and state [Informative]

`working_memory.max_tokens=4k`; `eviction=recency_then_importance`
`episodic_memory: per mission_id journal (inputs → diffs → PR/template → rationale)`; `ttl=365d`
`semantic_memory: namespaces=["policies","baselines","rca","redteam","standards"]`;
`embeddings=text-embedding-sec-v1`; `k=10`
`durable_state_store: event-sourced journal`; snapshot on each PR and artifact ACK
`consistency: at-least-once (PR); exactly-once (template, rationale via digest)`
`idempotency: as per Output Contracts`

Decision and routing logic [Informative]

$\text{update_priority} = 0.35 \cdot \text{incident_severity} + 0.25 \cdot \text{exploitability_signal} + 0.25 \cdot \text{control_gap} + 0.15 \cdot \text{regulatory_urgency}$

All components in [0,1]; weights sum to 1.0 and must be recorded in explanation_ref.

routing: PR → Git; Template → artifact/OCI; Rationale → evidence registry;
backpressure when queue_depth > threshold

Model Risk Management [Informative]

kill_switch on diffs touching forbidden paths; sandbox mode if missing
provenance/attestation

red_team: adversarial suggestions attempting control weakening → require HITL and
deny if token missing

model drift: weekly check on diff accuracy and citation coverage; rollback if below
thresholds

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; policy_refs; hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and
legal_hold

Incident Response Integration [Informative]

link to motivating incident/mission; add SIEM/IR case references in PR body and
RationaleRecord

Change Impact Assessment [Informative]

(optional) compute change_impact_score on affected baselines; gate to
staging/production per thresholds

Stakeholder Feedback Loop [Informative]

(optional) capture reviewer labels {helpful|neutral|harmful}; update prompt_pack or
rubric after governance review (never auto-train on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress
legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: RCA repo; Red/Purple-Team results; Standards feeds
Produces: OC-1 PolicyPR; OC-2 BaselineTemplate; OC-3 RationaleRecord

Safety and abuse prevention [Informative]

blast_radius caps: max N diffs/hour/repo; deny removals of critical rules unless HITL token present
cost/QPS limits against sources and repos

Testing and validation [Informative]

contract tests (schema conformance, idempotency, ack windows)
offline replay of historical missions; generated diffs must compile and pass validators

Deployment and lifecycle [Informative]

HPA on input rate; shard by repository or baseline id
canary diff generation; rollback on validator/regression failure
SBOM + SLSA/in-toto attestations; sign artifacts and rationale manifests

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, AC-5/AC-6, IA-2; linkage to 800-61 for RCA); NIST CSF 2.0; ISO/IEC 27002:2022; MITRE ATT&CK (e.g., T1548.003); CIS Benchmarks; SCAP (XCCDF/OVAL); OPA/Rego

MCP-Native Protocol Specification (A4) [Normative]

- **Native Protocol(s) Consumed:** RCA Findings (REST/Markdown/JSON); Red/Purple-Team Results (REST/JSON); Regulatory/Standards Feeds (RSS/Atom/REST)
- **Native Protocol(s) Produced:** Policy PRs (Git); Baseline Templates (YAML/OPA/SCAP); RationaleRecord (evidence registry)
- **MCP Context Fields:**
 - **Required:** mission_id; role="PolicyAuthoringAgent"; intent="govern"; explanation_ref; provenance.attestation (SPIFFE identity, signing KID)
 - **Optional:** policy_refs; classification; decision_basis (evidence_refs, confidence); legal_hold

- **Enforcement Note:** Merge and registry PEPs must require HITL tokens for control-weakening or CrownJewels edits; registry must verify signatures/digests; legal_hold forbids purge.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

A5. Evidence Collector Agent

Agent Blueprint [Informative]

Purpose: Harvest and normalize evidence (for audits and incidents), preserve chain-of-custody, and emit a signed **EvidenceManifest** of content-addressed artifacts (SHA-256).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **SIEM Logs** (REST/OTel/Kafka): detections, raw log batches, evidence URIs.
- **System Configuration Snapshots** (SSH/REST/object store): files, command outputs, configs.
- **Ticketing Systems** (ServiceNow/Jira REST): incidents, changes, problem records & attachments.
- **Chat/Collaboration** (Slack/Teams exports): war-room threads, approvals.

Model training / knowledge (what the LLM relies on):

- Chain-of-custody & admissibility rubric (prompt pack): what to collect, how to normalize, naming, timestamp policy, retention.
- RAG sources: evidence taxonomy, allowed collectors, redaction policy (PII/PHI), hashing/signing SOPs; **no sensitive evidence in training**—use evidence_refs at run-time.

- Guardrails: read-only connectors; write only to evidence bucket/registry and append-only audit chain; **mandatory SHA-256 and JWS signing** prior to any publish.

Decisions it makes (deterministic + model-assisted):

- Inclusion/exclusion of artifacts per scope and constraints (e.g., `read_only_hosts`, `snapshot_consistency`).
- Normalization (canonical format, UTC timestamps, filenames, metadata).
- De-duplication & integrity (verify hashes, re-hash, content-addressing checks).
- Classification & legal hold (default **C3** for evidence; set `legal_hold=true` if counsel/regulator invocation).
- Packaging (decide when to emit optional **EvidenceBundle** TAR+GZ and append **AuditChainRecord**).

Routing / where outputs go:

- Objects → evidence object store (content-addressed).
- **EvidenceManifest** → evidence registry (and stored alongside objects).
- Optional **EvidenceBundle** → object store (signed TAR+GZ).
- **AuditChainRecord** → append-only chain for tamper-evident sequencing.

Automation scope vs. manual/HITL:

- Fully automated: collection, hashing, signing, normalization, manifest/bundle creation, audit-chain append.
- **HITL required:** redaction of sensitive chat/ticket content before release outside security/legal; any scope expansion to assets under strict controls (e.g., live DB snapshots).
- Manual outside agent: privileged legal counsel notes/interviews; third-party discovery transfers.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **SIEM Logs (REST/OTel/Kafka)** — detections and raw event batches

2. **System Configuration Snapshots (SSH/REST/object store)** — files, command outputs, config states
3. **Ticketing Systems (ServiceNow/Jira REST)** — incidents, changes, problem records
4. **Chat/Collaboration (Slack/Teams exports)** — war-room threads, approvals

Example: Consumed Protocol — SIEM Logs (REST/OTel/Kafka) [Informative]

Native payload

```
{
  "batch_id": "siem-batch-2025-08-15-1315Z-001",
  "source": "siem",
  "events": [
    {
      "ts": "2025-08-15T13:15:04Z",
      "rule_id": "okta-impossible-travel",
      "severity": "high",
      "user": "E102993",
      "ip": "198.51.100.44",
      "geo": "US-CA"
    }
  ],
  "object_store_uri": "s3://evidence/siem/2025/08/15/siem-batch-1315Z-001.json",
  "sha256": "6d2f1c0b3f7d8c28a0bb2f7e0d8e2f14a2dbf9b0c9f0c6f1f6e4c6a2f0a9b1cc",
  "bytes": 58234
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "INC-45877",
    "thread_id": "uuid-siem-batch-1315Z-001",
    "task_id": "uuid-a5-task-0001",
    "role": "EvidenceCollectorAgent",
    "intent": "collect",
    "policy_refs": ["AU-9", "AU-12", "CA-7"],
  }
}
```

```

"classification": "C3",
"legal_hold": true,
"constraints": ["snapshot_consistency"],
"decision_basis": {
  "evidence_refs": ["s3://evidence/siem/2025/08/15/siem-batch-1315Z-001.json"],
  "confidence": 0.99,
  "explanation_ref": "uri://kb/evidence/siem-batch-ingest"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/evidence-collector-agent",
  "signing_kid": "kid-a5-siem-01",
  "attestation_ref": "uri://slsa/attestations/evidence-collector@sha256:siem01"
}
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — System Configuration Snapshots (SSH/REST/object store) [Informative]

Native payload

```

{
  "host": "srv-001",
  "collected_at": "2025-08-15T13:18:40Z",
  "artifacts": [
    {"path": "/etc/ssh/sshd_config", "sha256": "e3d9...7a1", "bytes": 4212},
    {"path": "/etc/sudoers", "sha256": "9bc1...f02", "bytes": 6128},
    {"cmd": "dpkg -l | sha256sum", "stdout_uri": "s3://evidence/sys/srv-001/dpkg.sha256.txt", "sha256": "2a77...c9e", "bytes": 20480}
  ]
}

```

```
],  
  "bundle_uri": "s3://evidence/sys/srv-001/snapshot-2025-08-15T131840Z.tar.gz",  
  "bundle_sha256":  
  "b1f7d6e5a4c3d2b1a0f9e8d7c6b5a4f3e2d1c0b9a8f7e6d5c4b3a2f1e0d9c8b7",  
  "bundle_bytes": 390122  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "INC-45877",  
    "thread_id": "uuid-sys-snapshot-srv-001-2025-08-15T131840Z",  
    "task_id": "uuid-a5-task-0002",  
    "role": "EvidenceCollectorAgent",  
    "intent": "collect",  
    "policy_refs": ["CM-6", "AU-9"],  
    "classification": "C3",  
    "legal_hold": true,  
    "constraints": ["read_only_hosts"],  
    "decision_basis": {  
      "evidence_refs": ["s3://evidence/sys/srv-001/snapshot-2025-08-  
15T131840Z.tar.gz"],  
      "confidence": 0.98,  
      "explanation_ref": "uri://kb/evidence/system-snapshot-chain-of-custody"  
    },  
    "provenance": {  
      "producer_spiffe": "spiffe://enterprise/grc/evidence-collector-agent",
```

```

    "signing_kid": "kid-a5-sys-02",
    "attestation_ref": "uri://slsa/attestations/evidence-collector@sha256:sys02"
  }
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Ticketing Systems (ServiceNow/Jira REST)

[Informative]

Native payload

```

{
  "ticket_id": "INC-45877",
  "opened_at": "2025-08-15T12:55:10Z",
  "priority": "P1",
  "summary": "Privilege escalation observed on srv-001",
  "work_notes_uri": "s3://evidence/tickets/INC-45877/work_notes.json",
  "attachments": [
    { "uri": "s3://evidence/tickets/INC-45877/sudoers.diff", "sha256": "9f11...aa2" },
    { "uri": "s3://evidence/tickets/INC-45877/timeline.md", "sha256": "0c8e...71b" }
  ]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "INC-45877",
    "thread_id": "uuid-ticket-INC-45877",
    "task_id": "uuid-a5-task-0003",

```

```

"role": "EvidenceCollectorAgent",
"intent": "collect",
"policy_refs": ["IR-4", "AU-9"],
"classification": "C2",
"legal_hold": true,
"decision_basis": {
  "evidence_refs": [
    "s3://evidence/tickets/INC-45877/work_notes.json",
    "s3://evidence/tickets/INC-45877/sudoers.diff"
  ],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/evidence/ticket-correlation"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/evidence-collector-agent",
  "signing_kid": "kid-a5-tkt-03",
  "attestation_ref": "uri://slsa/attestations/evidence-collector@sha256:tkt03"
}
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Chat/Collaboration (Slack/Teams exports)

[Informative]

Native payload

```

{
  "platform": "slack",
  "channel": "#incident-INC-45877",

```

```
"thread_ts": "1723724100.123456",
"exported_at": "2025-08-15T13:25:20Z",
"messages_uri": "s3://evidence/chat/INC-45877/thread-1723724100.json",
"sha256": "77ac...d09",
"participants": ["@ir.lead", "@linux.sre", "@comms"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "INC-45877",
    "thread_id": "uuid-chat-INC-45877-1723724100",
    "task_id": "uuid-a5-task-0004",
    "role": "EvidenceCollectorAgent",
    "intent": "collect",
    "policy_refs": ["IR-4", "AU-11"],
    "classification": "C3",
    "legal_hold": true,
    "constraints": ["redact_pii:true"],
    "decision_basis": {
      "evidence_refs": ["s3://evidence/chat/INC-45877/thread-1723724100.json"],
      "confidence": 0.96,
      "explanation_ref": "uri://kb/evidence/chat-export-redaction"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/evidence-collector-agent",

```

```

    "signing_kid": "kid-a5-chat-04",
    "attestation_ref": "uri://slsa/attestations/evidence-collector@sha256:chat04"
  }
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **EvidenceManifest** (object URIs + SHA-256, sizes, timestamps).
- Optional: **EvidenceBundle** (TAR+GZ) with signature; **AuditChainRecord** (append-only).

MCP context (required) [Informative]

mission_id; role="EvidenceCollectorAgent"; intent="collect"; provenance (SPIFFE ID, signing KID, attestation); **SHA-256** included for every stored item.

MCP context (optional) [Informative]

classification (often C3); legal_hold=true when invoked by counsel/regulator; decision_basis (evidence_refs, confidence, explanation_ref); constraints (e.g., read_only_hosts, snapshot_consistency).

Enforcement note [Informative]

PEPs must verify: (1) every artifact is **content-addressed (SHA-256)**, (2) manifests and bundles are **JWS-signed** by an allowed KID, (3) legal_hold=true forbids purge, (4) read_only_hosts and snapshot_consistency constraints are honored.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — trustworthy evidence flows supporting resilience decisions.

Related controls: AU-9, AU-11/12, IR-4, CA-7.

Automation feasibility [Informative]

High (collection/normalization/signing automated; disclosure/redaction often requires HITL).

Output Contracts (merged) [Informative]

OC-1: EvidenceManifest Publish (to Evidence Registry) [Informative]

- **Producer(s):** A5
- **Topic/Path:** POST /evidence/manifests and object store put
- **Schema/Format:** EvidenceManifest@1.1 (manifest_id, mission_id, items[{uri,sha256,bytes,collected_at}], bundle{uri,sha256,bytes}, signed_by, signature_jws, created_at, retention_days)
- **Classification:** C3
- **Delivery:** exactly-once (content-addressed; idempotent by sorted item digests)
- **Ordering:** per mission_id
- **Idempotency-Key:** sha256(sorted_item_sha256_list)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; alert and set legal_hold on repeated NACK
- **Side-Effects:** register in evidence index; verify JWS signature; trusted timestamping
- **HITL Token:** none
- **Observability:** trace_id, mission_id, evidence_refs
- **Retention/TTL:** 7 years; indefinite if legal_hold

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EvidenceManifest@1.1 | json_schema_uri=uri://schema/evidence-manifest-1.1.json | sha256= | producers=A5 | consumers=EVID-REG-01,AUDIT-PORTAL-01 | accepts=1.0–1.1 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EvidenceBundle Artifact (optional; TAR+GZ with signature) [Informative]

- **Producer(s):** A5
- **Topic/Path:** s3://evidence/bundles/<mission_id>/<manifest_id>.tar.gz

- **Schema/Format:** EvidenceBundle@1.0 (uri, sha256, bytes, includes manifest_id, signature_jws)
- **Classification:** C3
- **Delivery:** exactly-once (content-addressed)
- **Ordering:** per mission_id
- **Idempotency-Key:** sha256(manifest_id, tar_digest)
- **Ack/Nack:** 201 Created or object ETag; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x
- **Side-Effects:** cross-link from manifest; verify reproducible bundle build
- **HITL Token:** none
- **Observability:** trace_id, mission_id
- **Retention/TTL:** aligned to manifest

Schema Capsule (OC-2) [Normative]

Requirement Level: Optional

Condition: When packaging/bulk transfer is required (e.g., external regulator request)
 schema_id=EvidenceBundle@1.0 | json_schema_uri=uri://schema/evidence-bundle-1.0.json | sha256= | producers=A5 | consumers=EVID-REG-01 | accepts=1.0–1.0

Conformance: Normative when implemented.

OC-3: AuditChainRecord Append (append-only tamper-evident log) [Informative]

- **Producer(s):** A5
- **Topic/Path:** POST /auditchain/append
- **Schema/Format:** AuditChainRecord@1.0 (seq, prev_hash, curr_hash, manifest_id, actor_spiffe, ts)
- **Classification:** C2 (may reference C3 artifacts by URI only)
- **Delivery:** exactly-once per seq (service enforces monotonic sequence)
- **Ordering:** global by seq
- **Idempotency-Key:** sha256(seq, prev_hash, manifest_id)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx

- **Timeouts/Retry:** ack<=10s; exp-backoff<=5x; reconcile on hash mismatch
- **Side-Effects:** emit chain head to monitoring; alert on fork detection
- **HITL Token:** none
- **Observability:** trace_id, mission_id
- **Retention/TTL:** indefinite

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When a tamper-evident audit chain is deployed or required by policy/regulation

schema_id=AuditChainRecord@1.0 | json_schema_uri=uri://schema/auditchain-record-1.0.json | sha256= | producers=A5 | consumers=AUDIT-CHAIN-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, collecting, normalizing, hashing, storing, writing_manifest,
bundling, chain_append, awaiting_hitl, failed, closed }

transition(idle -> collecting) on mission start or new input

transition(collecting -> normalizing) when artifact fetched

transition(normalizing -> hashing) when canonicalization done

transition(hashing -> storing) when SHA-256 computed and verified

transition(storing -> writing_manifest) when all artifacts persisted

transition(writing_manifest -> bundling) when bundle requested or policy requires

transition(bundling -> chain_append) on bundle ACK

transition(writing_manifest -> chain_append) if no bundle

transition(* -> awaiting_hitl) when redaction required or legal approval needed

transition(* -> failed) on validation error, hash mismatch, or repeated NACK

timeout(writing_manifest, 30s) -> retry<=5 with exp backoff

idempotency_key:

- EvidenceManifest: sha256(sorted_item_sha256_list)
- EvidenceBundle: sha256(manifest_id, tar_digest)
- AuditChainRecord: sha256(seq, prev_hash, manifest_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 EvidenceManifest	Required	Always	Core chain-of-custody and evidence registry
OC-2 EvidenceBundle	Optional	Packaging/bulk transfer required (e.g., regulator request)	Efficient secure exchange
OC-3 AuditChainRecord	Conditionally Required	Tamper-evident chain required by policy/regulation or platform present	Non-repudiation; tamper detection & forensics

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **HITL required:** redaction prior to external sharing; scope expansion to sensitive/live systems; release when legal_hold=true.
- **Manual outside agent:** counsel interviews/notes; third-party discovery transfers.

SLOs and KPIs [Informative]

- IngestAck_p95 <= 10 s
- ManifestCreationLatency_p95 <= 30 s
- HashMismatchRate_30d <= 0.1 percent
- RedactionTurnaround_p95 <= 4 h

Outputs index [Informative]

[OC-1 EvidenceManifest], [OC-2 EvidenceBundle], [OC-3 AuditChainRecord]

Technical Implementation Details (A5) [Informative]

Model and training profile [Informative]

model_id=evidence-collector-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=evidence-collector-v1 (chain-of-custody, hashing/signing SOPs, redaction rubric)

RAG: sources={evidence taxonomy, collectors matrix, redaction policy, retention schedule, audit-chain rules}; max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: optional; exclude sensitive evidence; eval on integrity and rubric adherence

guardrails: read-only on sources; outputs must include SHA-256; JWS signing mandatory; deny non-content-addressed writes

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance

episodic_memory: per mission_id journal (artifact→hash→store→manifest); ttl=365d

semantic_memory: namespaces=["evidence", "policies", "redaction"]; embeddings=text-embedding-sec-v1; k=8

durable_state_store: event-sourced journal; manifest snapshots content-addressed

consistency: exactly-once (manifest, bundle via digest); at-least-once reads from sources

idempotency: per Output Contracts

Decision and routing logic [Informative]

selection_score = 0.4*relevance + 0.3*integrity_signal + 0.2*policy_required + 0.1*timeliness

Include artifacts with selection_score >= 0.6; defer to HITL if referenced by counsel but below threshold.

routing: objects→store; manifest→registry; bundle→store; chain append→audit chain; apply backpressure when queue_depth > threshold

Model Risk Management [Informative]

continuous_validation: daily golden replays; integrity gates (hash presence, signature) must pass=100 percent

red_team_cycle: adversarial tampering (hash mismatch, timestamp skew) → expect reject + alert

rollback_policy: if HashMismatchRate_7d > 0.1 percent → revert model_id to last good; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; hashes; policy_refs

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

link manifests and bundles to incident case IDs; emit chain head to SIEM for monitoring/alerting on forks

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress

legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: SIEM OTel/Kafka; SSH/REST/object; ServiceNow/Jira; Slack/Teams exports

Produces: OC-1 EvidenceManifest; OC-2 EvidenceBundle (optional); OC-3 AuditChainRecord

Safety and abuse prevention [Informative]

auto-legal_hold on counsel flag; PII redaction deny/allow lists; fork detection on audit chain; immutable object versioning

Testing and validation [Informative]

contract tests (schema conformance, idempotency, ack windows); reproduce hashes end-to-end
offline replay with prior incidents; acceptance on integrity checks and manifest completeness

Deployment and lifecycle [Informative]

HPA on ingest rate; shard by mission_id
canary manifest signing; rollback on signature validation failures
SBOM + SLSA/in-toto attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-92; NIST SP 800-86; NIST SP 800-137; SLSA / in-toto (provenance); W3C PROV (evidence lineage)

MCP-Native Protocol Specification (A5) [Normative]

- **Native Protocol(s) Consumed:** SIEM Logs (REST/OTel/Kafka); System Configuration Snapshots (SSH/REST/object); Ticketing Systems (ServiceNow/Jira); Chat/Collab exports (Slack/Teams)
- **Native Protocol(s) Produced:** EvidenceManifest (object URIs + SHA-256, sizes, timestamps); optional EvidenceBundle (TAR+GZ, signed); AuditChainRecord (append-only)
- **MCP Context Fields:**
 - **Required:** mission_id; role="EvidenceCollectorAgent"; intent="collect"; provenance (SPIFFE ID, signing KID, attestation); SHA-256 for every stored item
 - **Optional:** classification (often C3); legal_hold; decision_basis (evidence_refs, confidence, explanation_ref); constraints (read_only_hosts, snapshot_consistency)
- **Enforcement Note:** PEPs must verify content addressing, signatures, and legal_hold before release/purge; audit-chain service must enforce monotonic sequence and reject forks.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.

- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

A6. Control Monitor Agent

Agent Blueprint [Informative]

Purpose: Continuously measure security control effectiveness and SLOs; detect regressions/drift and emit **ControlStatus** updates and **DriftAlert** events (and optionally auto-open tickets per policy).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **OpenTelemetry (OTel) metrics/logs:** control coverage, error rates, SLO burn, measurement timestamps.
- **CSPM checks (REST/JSON):** cloud conformance results, control mappings (CIS/NIST).
- **Endpoint posture / EDR coverage (REST/gRPC):** sensor health, coverage vs. baseline policies.

Model training / knowledge (what the LLM relies on):

- Measurement & SLO rubric (prompt pack): how to interpret control metrics, apply targets, and decide **OK/WARNING/BREACH**.
- RAG sources: control catalog (NIST 800-53, CIS), SLO policy table (targets, windows, breach rules), asset scope definitions, historical baselines. **No regulated evidence in training**—use `evidence_refs` at run time.
- Guardrails: read-only on telemetry sources; write only to status/alert topics and ticketing endpoint when constraints include "auto_open_ticket"; cannot change SLO policy.

Decisions it makes (deterministic + model-assisted):

- SLO evaluation per control dimension (e.g., **AU-12 / endpoint_logging**) and state assignment.

- Drift detection: compare current vs. previous window, compute delta, apply tolerance thresholds.
- Auto-ticketing when breach policy dictates **and** constraints include "auto_open_ticket".
- Classification: default **C2**; raise to **C3** if payloads reference sensitive asset metadata.

Routing / where outputs go:

- **ControlStatus** → status stream (Kafka/AMQP) or REST status endpoint.
- **DriftAlert** → alert stream (Kafka/AMQP) and optional ticket create.
- **Tickets (optional)** → ServiceNow/Jira if the SLO binding's breach policy says so.

Automation scope vs. manual/HITL:

- Fully automated: ingest, evaluate, emit **ControlStatus/DriftAlert**, open tickets per policy.
- **HITL required:** any severity downgrade on CrownJewels controls after a breach; SLO overrides or temporary waivers.
- Manual outside agent: editing SLO targets/windows; regulator-specific narrative for audit reports.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1) OpenTelemetry (OTel) metrics/logs — control coverage, error rates, SLO burn

Native payload

```
{
  "resource": {"service.name": "control-observer", "service.namespace": "secops", "env": "production"},
  "metric": {
    "name": "control_slo_percent",
    "labels": {"control": "AU-12", "dimension": "endpoint_logging"},

```

```

    "type": "gauge",
    "value": 98.1,
    "timestamp": "2025-08-15T12:30:00Z"
  },
  "slo_target_percent": 98.0,
  "slo_window_hours": 168
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a6-otel-1111-2222-3333-4444",
    "thread_id": "uuid-control-AU-12-endpoint_logging",
    "task_id": "uuid-a6-task-0001",
    "role": "ControlMonitorAgent",
    "intent": "monitor",
    "policy_refs": ["AU-12", "CA-7"],
    "constraints": ["auto_open_ticket"],
    "slo_bindings": {
      "id": "SLO-AU12-endpoint_logging",
      "target_percent": 98.0,
      "window_hours": 168,
      "breach_policy": "open_ticket:P2_if_below_target_for>=2h"
    },
    "decision_basis": {
      "evidence_refs": ["uri://otel/metrics/control_slo_percent/AU-12/endpoint_logging/2025-08-15T12:30:00Z"],

```

```

    "confidence": 0.98,
    "explanation_ref": "uri://kb/controls/au12-measurement-method"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/grc/control-monitor-agent",
    "signing_kid": "kid-otel-a6-01",
    "attestation_ref": "uri://slsa/attestations/control-monitor@sha256:otel01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { }
}

```

2) CSPM checks (REST/JSON) — cloud control conformance

Native payload

```

{
  "check_id": "cis_aws_3_1",
  "title": "Ensure S3 buckets restrict public access",
  "result": "fail",
  "affected_resources": [{"arn": "arn:aws:s3:::logs-prod", "reason": "BlockPublicAcls=false"}],
  "mappings": ["SC-7", "CM-6", "CIS-AWS-3.1"],
  "evaluated_at": "2025-08-15T12:10:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {

```

```

"mcp_version":"0.9",
"mission_id":"uuid-a6-cspm-5555-6666-7777-8888",
"thread_id":"uuid-cspm-cis_aws_3_1",
"task_id":"uuid-a6-task-0002",
"role":"ControlMonitorAgent",
"intent":"monitor",
"policy_refs":["SC-7","CM-6"],
"constraints":["auto_open_ticket"],
"slo_bindings": {
  "id":"SLO-CSPM-s3-public-access",
  "target_percent":100.0,
  "window_hours":720,
  "breach_policy":"open_ticket:P1_on_first_fail"
},
"decision_basis":{
  "evidence_refs":["uri://cspm/checks/cis_aws_3_1/2025-08-15T12:10:00Z"],
  "confidence":0.95,
  "explanation_ref":"uri://kb/controls/cspm-s3-public-access"
},
"provenance":{
  "producer_spiffe":"spiffe://enterprise/grc/control-monitor-agent",
  "signing_kid":"kid-cspm-a6-02",
  "attestation_ref":"uri://slsa/attestations/control-monitor@sha256:cspm02"
},
"classification":"C2"
},

```

```
"native_payload": { }  
}
```

3) Endpoint posture / EDR coverage (REST/gRPC) — coverage and health

Native payload

```
{  
  "fleet": "linux-prod",  
  "policy": "Prod-Servers",  
  "coverage_percent": 97.4,  
  "unhealthy": 18,  
  "not_reporting_24h": 7,  
  "sampled_at": "2025-08-15T12:20:40Z",  
  "mappings": ["CM-6", "SI-3"]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-a6-edr-9999-aaaa-bbbb-cccc",  
    "thread_id": "uuid-edr-linux-prod",  
    "task_id": "uuid-a6-task-0003",  
    "role": "ControlMonitorAgent",  
    "intent": "monitor",  
    "policy_refs": ["CM-6", "SI-3"],  
    "constraints": ["auto_open_ticket"],  
    "slo_bindings": {  
      "id": "SLO-EDR-coverage-linux-prod",  
      "target_percent": 98.0,  

```

```

    "window_hours":168,
    "breach_policy":"open_ticket:P2_if_below_target_for>=4h"
  },
  "decision_basis":{
    "evidence_refs":["uri://edr/fleets/linux-prod/coverage/2025-08-15T12:20:40Z"],
    "confidence":0.96,
    "explanation_ref":"uri://kb/controls/edr-coverage-slo"
  },
  "provenance":{
    "producer_spiffe":"spiffe://enterprise/grc/control-monitor-agent",
    "signing_kid":"kid-edr-a6-03",
    "attestation_ref":"uri://slsa/attestations/control-monitor@sha256:edr03"
  },
  "classification":"C3"
},
"native_payload": { }
}

```

Outputs (native) [Informative]

- **ControlStatus** updates with SLO compliance state.
- **DriftAlert** when a control regresses beyond tolerance.
- **Optional:** Auto-open ticket when constraints include "auto_open_ticket" and breach policy dictates.

MCP context (required) [Informative]

mission_id; role="ControlMonitorAgent"; intent="monitor"; policy_refs; provenance (SPIFFE ID, signing KID, attestation); **slo_bindings** (id, target, window, breach policy). If ticketing is allowed, constraints **must** include "auto_open_ticket".

MCP context (optional) [Informative]

classification (C1–C3), legal_hold, decision_basis (evidence_refs, confidence, explanation_ref).

Enforcement note [Informative]

PEPs/consumers must verify **slo_bindings** and provenance; ticketing calls **MUST** be rejected unless "auto_open_ticket" is present; CrownJewels dimensions require HITL to downgrade severity.

NIST SP 800-160v2 linkage [Informative]

Maintain & Evaluate — continuous assurance of control effectiveness.

Automation feasibility [Informative]

High (telemetry → evaluation → status/alert/ticket flows are automatable; waivers/overrides require HITL).

Output Contracts (merged) [Informative]

OC-1: ControlStatus Publish (status stream and REST) [Informative]

- **Producer(s):** A6
- **Topic/Path:** kafka://control.status.v1 (or amqp://control.status.v1); REST: POST /controls/status
- **Schema/Format: ControlStatus@1.1**
 - Fields: control_id, dimension, slo_target_percent, observed_percent, state, window_hours, last_updated, evidence_refs, annotations{}
 - States: **OK | WARNING | BREACH**
- **Classification:** C2 (upgrade to C3 if dimension reveals sensitive asset group)
- **Delivery:** at-least-once
- **Ordering:** per (control_id, dimension)
- **Idempotency-Key:** sha256(control_id, dimension, last_updated_floor_60s, observed_percent_floor_0p1)
- **Ack/Nack:** broker ACK or HTTP 201; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; drop duplicates by idempotency key

- **Side-Effects:** update status cache; emit metrics ControlStatusLatency and ControlStateDistribution
- **HITL Token:** not required
- **Observability:** trace_id, mission_id, policy_refs, slo_bindings.id, decision_basis.confidence
- **Retention/TTL:** 180 days (events); 30 days (cache)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ControlStatus@1.1 | json_schema_uri=uri://schema/control-status-1.1.json | sha256= | producers=A6 | consumers=GRC-Dash-01, ISCM-DB-01 | accepts=1.0–1.1 (1.0 EOL 2026-03-31)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: DriftAlert Event (breach or fast regression) [Informative]

- **Producer(s):** A6
- **Topic/Path:** kafka://control.drift.v1 (or amqp://control.drift.v1); REST: POST /controls/drift
- **Schema/Format: DriftAlert@1.0**
 - Fields: alert_id, control_id, dimension, previous_percent, current_percent, delta_percent, threshold, state, detected_at, recommended_action, auto_ticket_opened, ticket_ref
- **Classification:** C2 (may reference C3 evidence via URIs)
- **Delivery:** at-least-once
- **Ordering:** per (control_id, dimension)
- **Idempotency-Key:** sha256(control_id, dimension, detected_at_floor_60s, delta_bucket_0p1)
- **Ack/Nack:** broker ACK or HTTP 201; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=15s; exp-backoff<=5x

- **Side-Effects:** trigger notification; update drift counters; optional auto ticket per breach policy
- **HITL Token:** required for severity downgrade on CrownJewels dimensions
- **Observability:** trace_id, mission_id, slo_bindings.id, decision_basis.explanation_ref
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When drift/threshold checks are enabled for a control dimension

schema_id=DriftAlert@1.0 | json_schema_uri=uri://schema/drift-alert-1.0.json | sha256= | producers=A6 | consumers=SecEng-Notify-01, Ticket-Broker-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

OC-3: AutoTicket Create (optional; invoked by breach policy) [Informative]

- **Producer(s):** A6 (only when constraints include "auto_open_ticket")
- **Topic/Path:** REST: POST /tickets/security_incident or GraphQL: createSecurityTicket
- **Schema/Format: AutoTicket@1.0**
 - Fields: ticket_ref, priority, summary, description, control_id, dimension, evidence_refs, policy_refs, breach_policy, assignee_group, due_date
- **Classification:** C2 (may reference C3 evidence via links)
- **Delivery:** exactly-once (consumer enforces idempotency by external_id)
- **Ordering:** per (control_id, dimension)
- **Idempotency-Key:** sha256(control_id, dimension, detected_at_floor_60s, breach_policy)
- **Ack/Nack:** HTTP 201; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=20s; exp-backoff<=5x; escalate to HITL after final NACK
- **Side-Effects:** back-link ticket_ref into originating DriftAlert; notify owner_group
- **HITL Token:** not required to open; **required to close** tickets for CrownJewels before ControlStatus returns to **OK** for 24h

- **Observability:** trace_id, mission_id, slo_bindings.id, decision_basis.confidence
- **Retention/TTL:** per ticketing policy (≥ 7 years)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When breach policy requires ticketing **and** constraints include "auto_open_ticket"

schema_id=AutoTicket@1.0 | json_schema_uri=uri://schema/auto-ticket-1.0.json | sha256= | producers=A6 | consumers=SNOW-API-01, JIRA-API-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, evaluating, status_emit, drift_compute, alert_emit, ticketing, awaiting_hitl, failed, closed }

transition(idle -> ingesting) on new telemetry or scheduled poll

transition(ingesting -> evaluating) when inputs for (control_id, dimension) in window resolved or timeout reached

transition(evaluating -> status_emit) when SLO state computed

transition(evaluating -> drift_compute) when previous window available

transition(drift_compute -> alert_emit) when |delta_percent| $\geq$ drift_threshold and policy applies

transition(alert_emit -> ticketing) when breach_policy requires ticket and constraints include "auto_open_ticket"

transition(alert_emit -> awaiting_hitl) when severity downgrade requested on CrownJewels

transition(* -> failed) on schema/validation error or repeated NACK

timeout(evaluating, 10s) -> proceed with partial data; set decision_basis.confidence $\leq$ 0.8

timeout(ticketing, 20s) -> retry $\leq$ 5; on failure -> awaiting_hitl

idempotency_key(ControlStatus) = sha256(control_id, dimension,
last_updated_floor_60s, observed_percent_floor_0p1)

idempotency_key(DriftAlert) = sha256(control_id, dimension, detected_at_floor_60s,
delta_bucket_0p1)

idempotency_key(AutoTicket) = sha256(control_id, dimension, detected_at_floor_60s,
breach_policy)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ControlStatus	Required	Always	Core control/SLO telemetry for governance
OC-2 DriftAlert	Conditionally Required	Drift monitoring enabled for the control dimension	Fast regression detection & escalation
OC-3 AutoTicket	Conditionally Required	Breach policy requires ticket and "auto_open_ticket" constraint is present	Rapid workflow activation for remediation

Requirement Level Definitions: **Required** = must implement; **Conditionally Required** = must implement when trigger fires; **Optional** = may implement for enhancements.

Policies and HITL gates [Informative]

- **HITL required:** severity downgrade from **BREACH** to **WARNING/OK** for CrownJewels; temporary SLO waiver/override; closing AutoTickets for CrownJewels before 24h in **OK**.
- **Manual outside agent:** editing SLO targets/windows; regulator narratives.
- **Blast-radius caps:** max auto-tickets per control per hour; debounce to prevent alert storms.

- **Classification:** default C2; elevate to C3 if payload contains sensitive scoping.

SLOs and KPIs [Informative]

- ControlStatusLatency_p95 ≤ 30 s
- DriftTimeToDetect_p95 ≤ 60 s
- AutoTicketOpenSuccess $\geq 99\%$
- FalseAlertRate_30d $\leq 1\%$
- BreachRecoveryVerification: 100% of tickets linked to ControlStatus returning to **OK**

Outputs index [Informative]

[OC-1 ControlStatus], [OC-2 DriftAlert], [OC-3 AutoTicket]

Technical Implementation Details (A6) [Informative]

Model and training profile [Informative]

model_id=control-monitor-text-model; temperature=0.15; max_tokens_out=600
 prompt_pack_id=control-monitor-v1 (SLO evaluation rules, drift math, ticket templates)
 RAG: sources={control catalog, SLO policy table, historical baselines, asset scopes};
 max_docs=8; min_similarity=0.78; citations required
 fine_tuning/adapters: optional; exclude regulated content; evaluate on SLO decision
 accuracy & false-alert rate
 guardrails: read-only to telemetry; write-scoped tokens to status/alert topics and ticket
 API; cannot mutate SLO policies

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per (control_id, dimension) rollups and last 2 windows; ttl=90d
 semantic_memory: namespaces=["controls","slo-policies","history"]; embeddings=text-
 embedding-sec-v1; k=8
 durable_state_store: time-series store for windowed aggregates; snapshot after each
 status emit
 consistency: at-least-once (ControlStatus/DriftAlert); exactly-once (AutoTicket via
 idempotency)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Control SLO check:

- state = **OK** if $\text{observed_percent} \geq \text{target_percent}$
- state = **WARNING** if below target but $\text{duration_below_target} < \text{breach_duration_threshold}$
- state = **BREACH** if below target and $\text{duration_below_target} \geq \text{breach_duration_threshold}$

Error budget:

$\text{error_budget_percent} = 100 - \text{target_percent}$

$\text{burned_percent} = \max(0, \text{target_percent} - \text{observed_percent})$

$\text{burn_rate} = \text{burned_percent} / \text{error_budget_percent}$ (over window)

Drift detection:

$\text{delta_percent} = \text{current_percent} - \text{previous_percent}$

$\text{breach_if_drift} = (\text{delta_percent} \leq -\text{drift_threshold_percent})$

Windowing:

$\text{observed_percent_windowed} = \text{avg}(\text{values over window_hours})$

$\text{duration_below_target} = \text{total_time}(\text{observed_percent_windowed} < \text{target_percent})$

routing: **status** → **status topic**; **alerts** → **drift topic**; **tickets** → **ticket API**; apply backpressure when $\text{queue_depth} > \text{threshold}$

Safety and abuse prevention [Informative]

Anti-flap debouncing & rate limits; cooldown per dimension; require "auto_open_ticket" to call ticket API; escalate if BREACH persists >24h on CrownJewels; auto-upgrade classification to C3 on sensitive scopes.

Testing and validation [Informative]

Contract tests (schemas, acks, idempotency); offline replay of historical weeks; red-team for missing/skewed data; weekly model-drift checks with rollback if FalseAlertRate exceeds threshold.

Deployment and lifecycle [Informative]

HPA on ingest rate; shard by (control_id, dimension); canary on new SLO rules; rollback on anomaly in ControlStateDistribution; SBOM + SLSA/in-toto attestations; sign release artifacts.

References / Standards [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

MCP-Native Protocol Specification (A6) [Normative]

- **Native Protocol(s) Consumed:** OTel metrics/logs; CSPM REST/JSON; EDR REST/gRPC
- **Native Protocol(s) Produced:** ControlStatus (Kafka/AMQP/REST); DriftAlert (Kafka/AMQP/REST); AutoTicket (optional) to ticketing platforms
- **MCP Context Fields:**
 - **Required:** mission_id; role="ControlMonitorAgent"; intent="monitor"; policy_refs; provenance (SPIFFE ID, signing KID, attestation); **slo_bindings** (id, target_percent, window_hours, breach_policy)
 - **Optional:** classification (C1–C3); legal_hold; decision_basis (evidence_refs, confidence, explanation_ref); **constraints** includes "auto_open_ticket" to enable ticketing
- **Enforcement Note:** Consumers MUST validate slo_bindings, provenance, and (for ticketing) presence of "auto_open_ticket"; HITL required to downgrade CrownJewels breaches.
- **Versioning/compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section and each **Schema Capsule** are [Normative] and define testable requirements.

A7. Metrics Aggregator Agent

Agent Blueprint [Informative]

Purpose: Compute and publish security KPIs/SLOs (e.g., MTTD, MTTR, Patch Latency, Drift Rate) and rollups for exec/board dashboards, with **audit-ready lineage** by storing formulas and input ranges in decision_basis.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **ActionOutcome stream (Kafka/AMQP/REST):** SOAR/EDR/orchestrators outcomes (containment, patch jobs, playbook steps).
- **ControlStatus updates (from A6):** SLO states per control/dimension.
- **Incident timeline (IR/Ticketing):** detection/containment/resolution timestamps, severity.

Model training / knowledge (what the LLM relies on):

- Metrics rubric (prompt pack): KPI definitions, rollup rules, window semantics, outlier handling (winsorize or z-score), cohort filters.
- RAG sources: metric dictionary, policy mapping (CA-7/IR-4/SI-2/CM-6), historical snapshots, data-lineage docs. **No sensitive event content in training**—use evidence_refs at run time.
- Guardrails: read-only on sources; writes limited to **MetricSnapshot** and **DashboardUpdate** topics/APIs; formulas immutable unless a signed **FormulaChange** request is present (**HITL**).

Decisions it makes (deterministic + model-assisted):

- Windowing & cohorting (e.g., rolling_28d; severity ∈ {P1,P2}; region filters).
- KPI computation (MTTD/MTTR/PatchLatencyP95/DriftRate/SLOCompliance%).
- Aggregation & normalization (per control, per BU, per environment).
- Narrative annotations for prominent movements.
- Classification: default **C1/C2** (no PII in snapshots/dashboards).

Routing / where outputs go:

- **MetricSnapshot** → metrics registry (events or REST).
- **DashboardUpdate** → BI/exec portal API (cards/sections) and analytics store.

Automation scope vs. manual/HITL:

- Fully automated: ingest → compute → publish snapshots/dashboards.
- **HITL required:** changes to formulas/normalizers/filters that alter board-level KPI semantics; **restatements** of previously published executive metrics.

- Manual outside agent: regulator-facing long-form narrative; enterprise KPI policy updates.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1) ActionOutcome Stream (Kafka/AMQP/REST)

Native payload

```
{
  "event_id": "ACT-2025-08-15-1322-0007",
  "source": "soar",
  "action_type": "containment.isolate_endpoint",
  "target": {"asset_id": "srv-001"},
  "started_ts": "2025-08-15T13:22:10Z",
  "ended_ts": "2025-08-15T13:22:25Z",
  "status": "success",
  "latency_ms": 15000,
  "related_incident": "INC-45877",
  "labels": {"playbook": "P-IR-Linux-PrivEsc"}
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a7-act-1111-2222-3333-4444",
    "thread_id": "uuid-activity-ACT-2025-08-15-1322-0007",
    "task_id": "uuid-a7-task-0001",
    "role": "MetricsAggregatorAgent",
  }
}
```

```

    "intent": "measure",
    "policy_refs": ["IR-4", "CA-7"],
    "constraints": ["window:rolling_28d"],
    "decision_basis": {
      "formula": "MTTR component uses step latencies for containment and resolution
phases.",
      "input_ranges": {"time_window_start": "2025-07-18T00:00:00Z",
"time_window_end": "2025-08-15T23:59:59Z"},
      "evidence_refs": ["uri://kafka/actionoutcomes/ACT-2025-08-15-1322-0007"],
      "confidence": 0.98,
      "explanation_ref": "uri://kb/metrics/definitions#mttr"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/grc/metrics-aggregator-agent",
      "signing_kid": "kid-a7-act-01",
      "attestation_ref": "uri://slsa/attestations/metrics-aggregator@sha256:act01"
    },
    "classification": "C1",
    "legal_hold": false
  },
  "native_payload": {}
}

```

2) ControlStatus Updates (Kafka/REST)

Native payload

```

{
  "control_id": "AU-12",
  "dimension": "endpoint_logging",

```

```
"slo_target_percent": 98.0,  
"observed_percent": 98.1,  
"state": "OK",  
"window_hours": 168,  
"last_updated": "2025-08-15T12:30:05Z",  
"evidence_refs": ["uri://otel/metrics/control_slo_percent/AU-12/endpoint_logging/2025-08-15T12:30:00Z"]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-a7-ctrl-5555-6666-7777-8888",  
    "thread_id": "uuid-controlstatus-AU-12-endpoint_logging",  
    "task_id": "uuid-a7-task-0002",  
    "role": "MetricsAggregatorAgent",  
    "intent": "measure",  
    "policy_refs": ["CA-7", "AU-12"],  
    "constraints": ["window:rolling_28d"],  
    "decision_basis": {  
      "formula": "SLOCompliance% = 100 * compliant_datapoints / total_datapoints",  
      "input_ranges": {"window_hours": 168},  
      "evidence_refs": ["uri://otel/metrics/control_slo_percent/AU-12/endpoint_logging/2025-08-15T12:30:00Z"],  
      "confidence": 0.97,  
      "explanation_ref": "uri://kb/metrics/definitions#slo-compliance"  
    },  
  },  
}
```

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/metrics-aggregator-agent",
  "signing_kid": "kid-a7-ctrl-02",
  "attestation_ref": "uri://slsa/attestations/metrics-aggregator@sha256:ctrl02"
},
"classification": "C1"
},
"native_payload": {}
}

```

3) Incident Timeline (IR/Ticketing REST)

Native payload

```

{
  "incident_id": "INC-45877",
  "severity": "P1",
  "category": "PrivilegeEscalation",
  "incident_start_ts": "2025-08-15T12:55:10Z",
  "detection_ts": "2025-08-15T13:20:10Z",
  "containment_ts": "2025-08-15T13:22:25Z",
  "resolution_ts": "2025-08-15T14:05:00Z",
  "owner_group": "sec.ir"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-a7-inc-9999-aaaa-bbbb-cccc",
    "thread_id": "uuid-incident-INC-45877",

```

```

"task_id": "uuid-a7-task-0003",
"role": "MetricsAggregatorAgent",
"intent": "measure",
"policy_refs": ["IR-4", "CA-7"],
"constraints": ["window:rolling_28d"],
"decision_basis": {
  "formula": "MTTD = avg(detection_ts - incident_start_ts); MTTR = avg(resolution_ts
- detection_ts)",
  "input_ranges": {"min_incidents": 30, "max_outlier_zscore": 3.0},
  "evidence_refs": ["uri://servicenow/incidents/INC-45877"],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/metrics/definitions#mttd-mttr"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/grc/metrics-aggregator-agent",
  "signing_kid": "kid-a7-inc-03",
  "attestation_ref": "uri://slsa/attestations/metrics-aggregator@sha256:inc03"
},
"classification": "C2"
},
"native_payload": {}
}

```

Outputs (native) [Informative]

- **MetricSnapshot** (per KPI/SLO, per window).
- **DashboardUpdate** (aggregated metrics for BI/exec views).

MCP context (required) [Informative]

mission_id; role="MetricsAggregatorAgent"; intent="measure"; **decision_basis** must include: formula, input_ranges, evidence_refs, confidence; provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

policy_refs (e.g., CA-7, IR-4, SI-2, CM-6); classification **C1–C2**; constraints (e.g., window:rolling_28d, region:us-east-1); legal_hold (default false).

Enforcement note [Informative]

Consumers and auditors must verify that every published snapshot includes complete lineage in decision_basis. **Formula** changes require a signed request and **HITL** approval; **restatements** of executive metrics require HITL and version bump.

NIST SP 800-160v2 linkage [Informative]

Maintain & Evaluate — quantitative evidence for resilience decisions and performance governance.

Automation feasibility [Informative]

High (windowing/computation/publication are automatable; policy/board-level semantics changes require HITL).

Output Contracts (merged) [Informative]

OC-1: MetricSnapshot Publish [Informative]

- **Producer(s):** A7
- **Topic/Path:** kafka://sec.metrics.snapshots.v1 (or AMQP); REST: POST /metrics/snapshots
- **Schema/Format: MetricSnapshot@1.1**
 - Fields: snapshot_id, window_start, window_end, kpis{...}, population{...}, notes
- **Classification:** C1 (may reference C2 evidence via URIs)
- **Delivery:** exactly-once (content-addressed by window + cohort + filters)
- **Ordering:** per (window_start, window_end, cohort_id)
- **Idempotency-Key:** sha256(window, cohort_id, filters_digest, kpi_digest)

- **Ack/Nack:** 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack≤30s; exp-backoff≤5×; on final NACK → HITL flag
- **Side-Effects:** register lineage (formulas + input_ranges) in catalog; emit MetricSnapshotLatency metric
- **HITL Token:** required to **restate** a previously published snapshot
- **Observability:** trace_id, mission_id, decision_basis.explanation_ref, constraints
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=MetricSnapshot@1.1 | json_schema_uri=uri://schema/metric-snapshot-1.1.json | sha256= | producers=A7 | consumers=BI-Warehouse-01, Exec-Portal-01 | accepts=1.0–1.1

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: DashboardUpdate Publish [Informative]

- **Producer(s):** A7
- **Topic/Path:** REST: POST /dashboards/{dashboard_id}/updates
- **Schema/Format: DashboardUpdate@1.0**
 - Fields: dashboard_id, as_of, sections[{{title, cards[{metric, values or value_percent/value_hours, targets}]}}
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per dashboard_id
- **Idempotency-Key:** sha256(dashboard_id, as_of_floor_1h, section_digest)
- **Ack/Nack:** 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack≤20s; exp-backoff≤5×
- **Side-Effects:** store snapshot↔dashboard linkage; notify subscribers

- **HITL Token:** required for **board** (CEO/Board) dashboards if values deviate > X% **and** the formula changed this quarter
- **Observability:** trace_id, mission_id, evidence_refs=[snapshot_id], decision_basis.formula
- **Retention/TTL:** dashboard policy (≥ 3 years)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When dashboards are in scope or policy mandates executive reporting
 schema_id=DashboardUpdate@1.0 | json_schema_uri=uri://schema/dashboard-update-1.0.json | sha256= | producers=A7 | consumers=Exec-Portal-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, windowing, computing, validating,
 publishing_snapshot, publishing_dashboard, awaiting_hitl, failed, closed }

transition(idle -> ingesting) on new data or schedule tick

transition(ingesting -> windowing) when inputs buffered for window or timeout

transition(windowing -> computing) when cohort/filters locked

transition(computing -> validating) after KPIs computed

transition(validating -> publishing_snapshot) when schema + lineage complete

transition(publishing_snapshot -> publishing_dashboard) on ACK and policy requires dashboards

transition(* -> awaiting_hitl) on restatement request, formula change, or repeated NACK

transition(* -> failed) on schema violation or lineage missing

timeout(validating, 10s) -> retry; if lineage missing -> awaiting_hitl

idempotency_key(snapshot) = sha256(window, cohort_id, filters_digest, kpi_digest)

idempotency_key(dashboard) = sha256(dashboard_id, as_of_floor_1h, section_digest)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 MetricSnapshot	Required	Always	Auditable KPI/SLO source of truth
OC-2 DashboardUpdate	Conditionally Required	Dashboards in use or policy mandates exec reporting	Executive/board decision visibility

Requirement Level Definitions: **Required** = must implement; **Conditionally Required** = must implement when trigger fires; **Optional** = may implement.

Policies and HITL gates [Informative]

- **HITL required:** formula/normalizer/filter changes; **restatements**; board dashboards with policy variance.
- Manual outside agent: regulatory narrative; quarterly KPI policy updates.
- Blast-radius caps: max restatements per quarter; dual approval for board dashboards.

SLOs and KPIs (for A7) [Informative]

- SnapshotLatency_p95 ≤ 30 s from window close
- DashboardPublishSuccess $\geq 99.5\%$
- LineageCompleteness = 100% (decision_basis has formula + input_ranges + evidence_refs)
- RestatementRate_qtr $\leq 1\%$

Outputs index [Informative]

[OC-1 MetricSnapshot], [OC-2 DashboardUpdate]

Technical Implementation Details (A7) [Informative]

Model and training profile [Informative]

model_id=metrics-aggregator-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=metrics-agg-v1 (windowing, KPI definitions, anomaly notes)
RAG: sources={metrics dictionary, lineage catalog, historical snapshots, KPI policy};
max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: optional; exclude sensitive incident content; eval on formula
fidelity & lineage completeness
guardrails: **deny** writes without lineage; **deny** formula changes without signed
FormulaChange ticket

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per-window journal (inputs→compute→publish); ttl=180d
semantic_memory: namespaces=["metrics","lineage","policy"]; embeddings=text-
embedding-sec-v1; k=8
durable_state_store: warehouse tables (snapshots, dashboards, lineage); snapshots
immutable unless restated with HITL
consistency: exactly-once for snapshots (idempotency key); at-least-once for
dashboards
idempotency: per Output Contracts

Decision & routing logic (explicit formulas) [Informative]

- $MTTD_minutes = minutes(detection_ts - incident_start_ts)$
- $MTTR_minutes = minutes(resolution_ts - detection_ts)$
- $PatchLatency_hours = hours(patch_applied_ts - advisory_published_ts)$ (filter: $cvss \geq 9.0$ OR $kev = true$)
- $PatchLatencyP95_hours = percentile(PatchLatency_hours, 95)$
- $DriftRate_per_100_assets_per_week = (DriftAlert_count / \max(asset_count_normalizer, 1)) * (100 / assets_unit) * (7 / window_days)$
- $SLOCompliance_percent = 100 * compliant_datapoints / \max(total_datapoints, 1)$
- **Outliers:** drop if $zscore > \max_outlier_zscore$ or winsorize at p1/p99 (policy)

routing: **snapshots** → **registry**; **dashboards** → **exec portal**; apply backpressure when
compute queue is high

Safety and abuse prevention [Informative]

Lineage enforcement; restatement workflow with dual HITL approval; rate limits for dashboard pushes; window freeze on quarter close.

Testing and validation [Informative]

Contract tests (schemas, idempotency, ACK windows); offline replay of prior quarters; reconcile with ground truth; red-team (manipulated timestamps, missing data, clock skews) ⇒ conservative compute or defer/HITL; monthly KPI fidelity audit.

Deployment and lifecycle [Informative]

HPA on event rate; shard by cohort_id; canary new KPI formulas behind feature flags; SBOM + SLSA/in-toto attestations; sign snapshot artifacts.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CA-7, IR-4, SI-2, CM-6, PM-5); NIST SP 800-137; FIRST EPSS; CISA KEV; OpenTelemetry Specification.

MCP-Native Protocol Specification (A7) [Normative]

- **Native Protocol(s) Consumed:** ActionOutcome (Kafka/AMQP/REST); ControlStatus (Kafka/REST); Incident Timeline (IR/Ticketing REST)
- **Native Protocol(s) Produced:** MetricSnapshot (per KPI/SLO, per window); DashboardUpdate (aggregated metrics for BI/exec)
- **MCP Context Fields:**
 - **Required:** mission_id; role="MetricsAggregatorAgent"; intent="measure"; decision_basis {formula, input_ranges, evidence_refs, confidence}; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (C1–C2); constraints (e.g., window:rolling_28d, region:us-east-1); legal_hold=false
- **Enforcement Note:** Validators MUST reject outputs lacking complete lineage; formula changes and restatements MUST carry HITL approvals and versioned lineage.
- **Versioning/compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.

- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** `decision_basis.formula`, `decision_basis.input_ranges`, and `provenance.attestation` are exposed to downstream UIs/APIs.

Conformance: This section and each **Schema Capsule** are **[Normative]** and define testable requirements.

A8. Supplier Risk Agent

Agent Blueprint [Informative]

Purpose: Perform third-party risk management (TPRM): score vendors, validate attestations, and emit **IntegrationPolicy** (allow/block/conditional) under data-sovereignty constraints.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Security Questionnaires (SIG/CAIQ-style JSON/CSV):** controls posture & practices, attachments (e.g., SOC 2).
- **SBOMs (CycloneDX/SPDX):** components, licenses, optional vulnerability linkage.
- **Supply-Chain Attestations (SLSA / OCTAVE / in-toto):** provenance, levels, signatures.

Model training / knowledge (what the LLM relies on):

- Scoring & mapping rubric (prompt pack): question weighting, SBOM heuristics, SLSA normalization; mappings to NIST 800-53 (SA-12, SA-15, SR-3/5) and NIST 800-161.
- RAG sources: questionnaire catalog, SBOM schema dictionary, SLSA/OCTAVE references, internal threshold tables. **No sensitive documents embedded**—use `evidence_refs` at run time.
- Guardrails: read-only on vendor artifacts; writes limited to **VendorRiskScore** (GRC/TPRM) and **IntegrationPolicy** (procurement/SOAR/API gateways); must enforce constraints for region/sovereignty.

Decisions it makes (deterministic + model-assisted):

- Normalize inputs; compute `risk_score` $\in [0,1]$ and vector components.

- Validate attestations (signature, level claims, timestamp freshness).
- Draft **IntegrationPolicy** (allow/block/conditional) with enforceable conditions (data residency, network boundary, logging, vuln remediation, reassessment cadence).
- Classification: default **C2**; elevate to **C3** if sensitive docs or regulated evidence are referenced.

Routing / where outputs go:

- **VendorRiskScore** → GRC/TPRM system.
- **IntegrationPolicy** → procurement workflow, SOAR, API gateways / egress filters.

Automation scope vs. manual/HITL:

- Fully automated: ingest, normalization, scoring, attestation validation, policy drafting.
- **HITL required:** conditional exceptions; overrides that would allow vendors with `risk_score ≥ policy.theta_block`; waivers of region/sovereignty constraints.
- Manual outside agent: legal negotiation & redlines; vendor communications.

Security Domain: Governance, Risk, and Compliance (GRC) & Oversight

Inputs (native protocols consumed) [Informative]

1. **Security Questionnaires (SIG/CAIQ-style)** — controls posture & practices
Native payload

```
{
  "vendor_id": "ven-axion-042",
  "questionnaire_id": "CAIQ-v4-lite",
  "responses": [
    {"id": "IAM-01", "text": "MFA required for admins", "answer": "Yes", "weight": 3},
    {"id": "LOG-03", "text": "Centralized audit logging", "answer": "Partial", "weight": 2},
    {"id": "DPA-07", "text": "Data residency guarantees (EEA)", "answer": "No", "weight": 4}
  ]
}
```

```
],  
  "attachments": ["s3://tprm/ven-axion-042/policies/SOC2-Type2-2025.pdf"],  
  "submitted_at": "2025-08-10T17:22:00Z"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "TPRM-2025-Q3",  
    "thread_id": "uuid-questionnaire-ven-axion-042",  
    "task_id": "uuid-a8-task-q-01",  
    "role": "SupplierRiskAgent",  
    "intent": "govern",  
    "constraints": ["region:EU", "data_sovereignty:EEA-only"],  
    "policy_refs": ["SR-3", "SR-5", "SA-12"],  
    "decision_basis": {  
      "evidence_refs": [  
        "uri://tprm/questionnaires/ven-axion-042/CAIQ-v4-lite",  
        "s3://tprm/ven-axion-042/policies/SOC2-Type2-2025.pdf"  
      ],  
      "confidence": 0.92,  
      "explanation_ref": "uri://kb/tprm/scoring#questionnaire"  
    },  
    "provenance": {  
      "producer_spiffe": "spiffe://enterprise/grc/supplier-risk-agent",  
      "signing_kid": "kid-a8-q-01",
```

```

    "attestation_ref": "uri://slsa/attestations/supplier-risk@sha256:q01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": {}
}

```

2. **SBOMs (CycloneDX JSON or SPDX 2.3)** — components, licenses, vulnerabilities

Native payload (CycloneDX 1.5 excerpt)

```

{
  "bomFormat": "CycloneDX",
  "specVersion": "1.5",
  "serialNumber": "urn:uuid:2d2c6c1a-1f9a-4a2a-9d4a-0a5e3e1b8c77",
  "version": 1,
  "metadata": {"supplier": {"name": "Axion Ltd"}},
  "components": [
    {"name": "openssl", "version": "1.1.1u", "licenses": [{"license": {"id": "OpenSSL"}}]},
    {"name": "log4j-core", "version": "2.14.1", "licenses": [{"license": {"id": "Apache-2.0"}}]}
  ],
  "vulnerabilities": [
    {"id": "CVE-2021-44228", "affects": [{"ref": "log4j-core@2.14.1"}], "ratings": [{"severity": "CRITICAL"}]}
  ]
}

```

MCP-wrapped payload

```

{

```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "TPRM-2025-Q3",
  "thread_id": "uuid-sbom-ven-axion-042",
  "task_id": "uuid-a8-task-sbom-02",
  "role": "SupplierRiskAgent",
  "intent": "govern",
  "constraints": ["region:EU", "data_sovereignty:EEA-only"],
  "policy_refs": ["SA-12", "SA-15", "SR-5"],
  "decision_basis": {
    "evidence_refs": ["uri://sbom/cyclonedx/ven-axion-042/latest.json"],
    "confidence": 0.94,
    "explanation_ref": "uri://kb/tpm/scoring#sbom"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/grc/supplier-risk-agent",
    "signing_kid": "kid-a8-sbom-02",
    "attestation_ref": "uri://slsa/attestations/supplier-risk@sha256:sbom02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": {}
}

```

3. Software Supply-Chain Attestations (SLSA / OCTAVE; in-toto) Native payload (summary)

```
{
```

```

"predicateType": "https://slsa.dev/provenance/v1",
"buildType": "https://slsa.dev/controlled-build/v1",
"builder": {"id": "https://builder.axion.example/tekton"},
"invocation": {"configSource": {"uri": "git+ssh://git.axion/app#refs/tags/v3.2.1"}},
"materials": [
  {"uri": "pkg:npm/react@18.2.0", "digest": {"sha256": "abc..."}},
  {"uri": "git+ssh://git.axion/lib-crypto@sha256:9af..."}
],
"slsaLevel": "L3",
"timestamp": "2025-08-09T10:00:00Z",
"signature_jws": "eyJhbGciOiJIJFZERTQ5...snip..."
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "TPRM-2025-Q3",
    "thread_id": "uuid-slsa-ven-axion-042",
    "task_id": "uuid-a8-task-slsa-03",
    "role": "SupplierRiskAgent",
    "intent": "govern",
    "constraints": ["region:EU", "data_sovereignty:EEA-only"],
    "policy_refs": ["SA-15", "SR-5"],
    "decision_basis": {
      "evidence_refs": ["uri://attestations/slsa/ven-axion-042/prov-2025-08-09.json"],
      "confidence": 0.95,
    }
  }
}

```

```

    "explanation_ref": "uri://kb/tpm/scoring#attestation"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/grc/supplier-risk-agent",
    "signing_kid": "kid-a8-slsa-03",
    "attestation_ref": "uri://slsa/attestations/supplier-risk@sha256:slsa03"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": {}
}

```

Outputs (native) [Informative]

- **VendorRiskScore** (numeric + vector) to GRC/TPRM.
- **IntegrationPolicy** (allow/block/conditions) to procurement/SOAR/API gateways.

MCP context (required) [Informative]

mission_id; role="SupplierRiskAgent"; intent="govern"; **constraints must include region/sovereignty rules** (e.g., "region:EU", "data_sovereignty:EEA-only"); provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

policy_refs (e.g., SR-3/5, SA-12/15, NIST 800-161); classification (C1–C3; **C3** if sensitive docs); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold.

Enforcement note [Informative]

Procurement, SOAR, and API gateway PEPs **must enforce** IntegrationPolicy decisions and **must** apply region/sovereignty constraints before enabling integrations.

NIST SP 800-160v2 linkage [Informative]

Develop / Implement / Maintain — supplier & chain resilience; continuous qualification and control inheritance checks.

Automation feasibility [Informative]

High (ingest, scoring, attestation validation, policy drafting). **HITL** for conditional exceptions and sovereignty waivers.

Output Contracts (merged) [Informative]

OC-1: VendorRiskScore Publish (to GRC/TPRM) [Informative]

- **Producer(s):** A8
- **Topic/Path:** REST POST /tprm/vendor_risk_scores (or GraphQL: createVendorRiskScore)
- **Schema/Format:** **VendorRiskScore@1.1** (fields: vendor_id, as_of, risk_score, risk_vector{questionnaire_score,sbom_score,attestation_score}, weights, key_findings[], recommendation, next_review_due)
- **Classification:** C2 (may reference C3 evidence via URIs)
- **Delivery:** at-least-once
- **Ordering:** per vendor_id
- **Idempotency-Key:** sha256(vendor_id, as_of_day_floor, inputs_digest)
- **Ack/Nack:** HTTP 201 / GraphQL success; NACK = 4xx/5xx
- **Timeouts/Retry:** ack≤30s; exp-backoff≤5×; on final NACK → open escalation ticket
- **Side-Effects:** write lineage to evidence index (weights, thresholds, evidence_refs)
- **HITL Token:** required if recommendation would **allow** when risk_score ≥ policy.theta_block
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.explanation_ref
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=VendorRiskScore@1.1 | json_schema_uri=uri://schema/vendor-risk-score-1.1.json | sha256= | producers=A8 | consumers=GRC-TPRM-01 | accepts=1.0–1.1

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: IntegrationPolicy Publish (allow/block/conditions) [Informative]

- **Producer(s):** A8
- **Topic/Path:** REST POST /tprm/integration_policies (or PUT /tprm/integration_policies/{policy_id})
- **Schema/Format: IntegrationPolicy@1.0** (fields: policy_id, vendor_id, decision ∈ {allow, block, allow_with_conditions}, conditions[], expiry_ttl_days, effective_from, routing{egress_regions_allowed[], deny_regions[]})
- **Classification:** C2
- **Delivery:** exactly-once (consumer enforces idempotency by policy_id)
- **Ordering:** per vendor_id
- **Idempotency-Key:** sha256(policy_id, vendor_id, decision, conditions_digest, effective_from_day_floor)
- **Ack/Nack:** HTTP 201/200; NACK = 4xx/5xx
- **Timeouts/Retry:** ack≤30s; exp-backoff≤5×; escalate to HITL on repeated NACK
- **Side-Effects:** propagate to SOAR/PEP caches; notify procurement and API gateway controllers
- **HITL Token:** required for **waivers** of region/sovereignty conditions or for **allow** when risk_score ≥ policy.theta_block
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.confidence, classification_label
- **Retention/TTL:** policy lifetime + 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When integrations/procurement gating is in scope or any vendor enters production data flows

schema_id=IntegrationPolicy@1.0 | json_schema_uri=uri://schema/integration-policy-1.0.json | sha256= | producers=A8 | consumers=PROC-API-01, SOAR-PEP-01 | accepts=1.0–1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, normalizing, scoring, validating_attestations,
drafting_policy, writing_vrs, awaiting_hitl, failed, closed }

transition(idle -> ingesting) on new questionnaire/SBOM/attestation

transition(ingesting -> normalizing) when formats parsed and deduped

transition(normalizing -> scoring) when feature vectors ready

transition(scoring -> validating_attestations) if attestation present or required

transition(validating_attestations -> drafting_policy) on signature+level pass (else -> awaiting_hitl)

transition(drafting_policy -> writing_vrs) when policy draft aligns with thresholds and constraints

transition(writing_vrs -> closed) on VRS ACK (optionally also publish IntegrationPolicy)

transition(* -> awaiting_hitl) on sovereignty waiver request or risky allow decision

transition(* -> failed) on schema/validation error or repeated NACK

timeout(writing_vrs, 30s) -> retry≤5 with exp backoff

idempotency_key(VRS) = sha256(vendor_id, as_of_day_floor, inputs_digest)

idempotency_key(Policy) = sha256(policy_id, vendor_id, decision, conditions_digest, effective_from_day_floor)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 VendorRiskScore	Required	Always	Authoritative vendor risk posture
OC-2 IntegrationPolicy	Conditionally Required	When gating integrations/procurement or vendor enters prod flows	Enforceable supplier access & data controls

Requirement Level Definitions: **Required** = must implement; **Conditionally Required** = must implement when trigger fires; **Optional** = may implement.

Policies and HITL gates [Informative]

- **HITL required:** conditional exceptions; allow when risk_score $\geq$ policy.theta_block; any waiver of region/sovereignty constraints.
- Manual outside agent: legal redlines; vendor communications.
- Blast-radius caps: maximum risky allows per quarter; auto-block if attestation stale beyond policy.max_age_days.
- Classification: default **C2**; upgrade to **C3** when sensitive docs (e.g., unredacted SOC2) are referenced.

SLOs and KPIs [Informative]

- VendorRiskScoreLatency_p95 $\leq$ 30 s
- PolicyPropagationLatency_p95 (to PEPs) $\leq$ 60 s
- FalseAllowRate_30d $\leq$ 1%
- SovereigntyViolationRate = 0
- EvidenceLineageCompleteness = 100%

Outputs index [Informative]

[OC-1 VendorRiskScore], [OC-2 IntegrationPolicy]

Technical Implementation Details (A8) [Informative]

Model and training profile [Informative]

model_id=supplier-risk-text-model; temperature=0.15; max_tokens_out=700
prompt_pack_id=tprm-scoring-v1 (weights, thresholds, sovereignty rules)
RAG: sources={questionnaire catalog, SBOM schema refs, SLSA docs, internal thresholds}; max_docs=8; min_similarity=0.78; citations required
fine_tuning/adapters: optional; exclude sensitive vendor docs; eval on calibration error & consistency
guardrails: enforce presence of constraints with region & data_sovereignty; deny writes lacking provenance/attestation

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per vendor mission journal; ttl=365d
semantic_memory: namespaces=["questionnaires", "sboms", "attestations", "thresholds"];
embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced journal; snapshot after each VRS/policy publish
consistency: at-least-once (VRS); exactly-once (Policy via idempotency key)
idempotency: per Output Contracts

Decision & routing logic (explicit) [Informative]

Risk scoring (0..1, higher = riskier):

questionnaire_score = 1 - (weighted_yes / weighted_total)

sbom_score = f1*vulns_critical_per_kloc + f2*pct_unknown_licenses +
f3*pct_outdated_critical

attestation_score = 1 - norm(attestation_level) // e.g., SLSA L0..L3+ → 0..1

risk = w_q*questionnaire_score + w_s*sbom_score + w_a*attestation_score

// where w_q + w_s + w_a = 1.0; persist weights in decision_basis

Policy decision (pseudo):

if risk >= theta_block or sovereignty_violation == true -> decision = "block"

else if risk >= theta_conditional or attestation_stale == true -> decision =
"allow_with_conditions"

else -> decision = "allow"

conditions include: data_residency, network_boundary, logging_slo, vuln_remediation, reassessment_cadence

routing: VRS → GRC/TPRM; IntegrationPolicy → procurement/SOAR/PEP;
backpressure when queue_depth > threshold

Transparency & Audit Trail [Informative]

decision_basis must include: evidence_refs, confidence, explanation_ref (weights, thresholds, attestation checks). Downstream UIs should expose classification_label, provenance.attestation, and a rationale URL.

Safety and abuse prevention [Informative]

Require valid signatures on attestations; enforce region/sovereignty constraints; rate-limit policy flips; dual approval for sovereignty waivers.

Testing and validation [Informative]

Contract tests (schemas, idempotency, ACK windows); offline replay of historical vendor sets; red-team (tampered attestations, doctored SBOMs) → expect **block** or **HITL**; calibration checks on risk distributions.

Deployment and lifecycle [Informative]

HPA on ingestion rate; shard by vendor_id; canary new weighting tables; SBOM of releases; SLSA/in-toto attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-161 Rev. 1; NIST SP 800-53 Rev. 5 (SA-12, SA-15; SR-3/5); SLSA v1.0; CycloneDX v1.5; SPDX 2.3; CSA CAIQ v4 / SIG Lite.

MCP-Native Protocol Specification (A8) [Normative]

- **Native Protocol(s) Consumed:** Security Questionnaires (SIG/CAIQ JSON/CSV); SBOMs (CycloneDX/SPDX); Supply-Chain Attestations (SLSA/OCTAVE/in-toto).
- **Native Protocol(s) Produced:** **VendorRiskScore** (GRC/TPRM); **IntegrationPolicy** (procurement/SOAR/API gateways).
- **MCP Context Fields — Required:**
mission_id; role="SupplierRiskAgent"; intent="govern"; **constraints** including

region/sovereignty (e.g., "region:EU","data_sovereignty:EEA-only"); provenance (SPIFFE ID, signing KID, attestation).

- **MCP Context Fields — Optional:**
policy_refs; classification (C1–C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold.
- **Enforcement Note:** PEPs and procurement systems MUST enforce IntegrationPolicy decisions and sovereignty constraints prior to enabling integrations.
- **Versioning & compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** expose classification_label, provenance.attestation, and decision_basis.explanation_ref to downstream UIs/APIs.

Conformance: This section and each **Schema Capsule** are **[Normative]** and define testable requirements.